

Insper

Avaliação Intermediária de Cibersegurança

Prof. João Eduardo Luisi

Privacy Guard

Extensão para Firefox de detecção e bloqueio de rastreadores

Relatório de execução: entregáveis 2, 3 e 4

Aluno: Kaua Makiyama

github.com/kauamakiyama/prova_cyber

São Paulo, setembro de 2026

Sumário

1. Introdução	3
1.1 Ambiente de teste	3
2. A extensão Privacy Guard	4
2.1 Arquitetura	4
2.2 Como cada requisito é detectado.....	4
3. Entregável 2: DuckDuckGo Privacy Test Pages	5
3.1 Tabela de resultados	5
3.2 Detalhamento por página.....	6
3.3 Defeitos revelados pelos testes e correções	22
4. Entregável 3: análise de 3 sites reais	25
4.1 Procedimento de coleta	25
4.2 Visão geral.....	25
4.3 g1.globo.com	25
4.4 mercadolivre.com.br	32
4.5 pt.wikipedia.org (site de controle).....	38
5. Entregável 4: pontuação de privacidade.....	43
5.1 Metodologia	43
5.2 Calibração.....	43
5.3 Aplicação aos 3 sites	44
5.4 Comparação crítica com o Blacklight	44
6. Conclusão	46
Anexo A: evidências no repositório.....	47

*(Se o sumário aparecer vazio, clique com o botão direito sobre ele no Word e escolha **Atualizar campo**.)*

1. Introdução

Este relatório documenta a validação da extensão **Privacy Guard**, desenvolvida para o Firefox com o objetivo de detectar e apresentar violações de privacidade no cliente web: conexões a domínios de terceira parte, cookies injetados (primeira/terceira parte, sessão/persistentes), armazenamento HTML5, sincronização de cookies e bounce tracking, canvas fingerprint, indicadores de sequestro de navegador (hijacking e hook) e uma pontuação de privacidade com metodologia explícita. A extensão também permite bloquear domínios por uma lista personalizada.

O relatório cobre os entregáveis exigidos pelo roteiro:

- **Entregável 2:** execução nas *DuckDuckGo Privacy Test Pages*, com resultado esperado × resultado do plugin × explicação de cada divergência (Seção 3);
- **Entregável 3:** análise de 3 sites reais (g1.globo.com, mercadolive.com.br e pt.wikipedia.org), com arquivo HAR e comparação com o Blacklight (The Markup) e com o uBlock Origin (Seção 4);
- **Entregável 4:** pontuação de privacidade, metodologia (critérios, pesos, justificativa), aplicação aos 3 sites e comparação crítica com o Blacklight (Seção 5).

1.1 Ambiente de teste

Item	Valor
Navegador	Mozilla Firefox 156.0.1, Windows 11, Proteção Aprimorada contra Rastreamento no modo Padrão
Extensão	Privacy Guard 0.8.0 (Manifest V2, JavaScript puro), carregada como temporária via <code>about:debugging</code>
Período	26 a 28/09/2026
Referências	DuckDuckGo Privacy Test Pages, Blacklight (The Markup), uBlock Origin 1.75.0, BrowserLeaks, DevTools (HAR)
Repositório	github.com/kauamakiyama/prova_cyber (código, README com a metodologia, pasta evidencias/ com HARs e prints)

Todos os prints citados estão no repositório em `evidencias/`; o caminho de cada arquivo aparece na legenda da figura. Os três HARs estão em `evidencias/sites/`.

2. A extensão Privacy Guard

2.1 Arquitetura

Arquivo	Responsabilidade
manifest.json	Manifest V2. Permissões webRequest, webRequestBlocking, storage, tabs, <all_urls>. Content scripts em todos os frames, em document_start.
background.js	Monitora a rede via webRequest (requisições, Set-Cookie, redirects, WebSocket), mantém o estado por aba, cadeia de navegação, cookie sync, polling, lista de bloqueio e calcula o score.
inject.js	Roda no contexto da página. Hooks em Storage.setItem, IDBFactory.open, APIs de canvas/WebGL/OffscreenCanvas, getters de iframes; retrato das globais e das funções nativas.
content.js	Injeta o inject.js antes dos scripts do site (inline, com fallback por <script src> se a CSP bloquear), repassa os eventos ao background por um canal com nome secreto e registra interação real do usuário.
popup/	Relatório da aba: score, domínios de 3ª parte, bloqueados, cookies, storage, bounce/sync, canvas, hijacking e gerenciamento da lista de bloqueio.

2.2 Como cada requisito é detectado

Requisito do roteiro	Técnica usada pela extensão
Domínios de 3ª parte	webRequest.onBeforeRequest; 3ª parte quando o eTLD+1 do host difere do eTLD+1 da página (lista reduzida de sufixos compostos, ex.: com.br).
Cookies injetados	onHeadersReceived lê cada Set-Cookie (RFC 6265). 1ª/3ª parte pelo eTLD+1 do Domain; sessão × persistente por Max-Age/Expires; exclusões (Max-Age<=0) ignoradas.
Armazenamento HTML5	Hooks em Storage.prototype.setItem e IDBFactory.prototype.open, com URL do script chamador (pilha), mais retrato das chaves após o carregamento; agrupado pela origem de cada frame.
Cookie sync / bounce tracking	Cadeia de navegação (redirect HTTP ou redirect por JavaScript em ≤ 5 s sem interação do usuário); salto de outro eTLD+1 = bounce; valores gravados no salto comparados aos parâmetros da URL final; parâmetros de rastreamento (gclid, fbclid, utm_*...); valor de cookie enviado na URL de outro domínio; redirect entre 3ªs partes com identificador.
Canvas fingerprint	Hooks de desenho e extração (fillText, drawImage, toDataURL, toBlob, getImageData, readPixels, OffscreenCanvas), também nas janelas de iframes. Critério de Englehardt & Narayanan (2016): ≥ 16×16 px, texto com ≥ 10 caracteres ou ≥ 2 cores, formato sem perda; ou WebGL.
Hijacking / hook	WebSocket para 3ª parte; polling persistente (mesmo endpoint de 3ª parte em ≥ 4 rodadas ao longo de ≥ 20 s); diff das globais de window; funções nativas sobrescritas (com autor provável: Sentry, zone.js, rrweb); assinatura do BeEF.
Score de privacidade	7 critérios com pesos que somam 100 (Seção 5).
Lista de bloqueio	Domínios em browser.storage.local; onBeforeRequest com blocking cancela o domínio e seus subdomínios, inclusive WebSocket e service workers.

3. Entregável 2: DuckDuckGo Privacy Test Pages

As páginas foram executadas no Firefox com a extensão carregada e a lista de bloqueio vazia (exceto no teste de Tracker Blocking, que exige um domínio na lista). Antes de cada teste, o código-fonte da página foi lido para saber exatamente o que ela faz, o que permitiu explicar as divergências com base no tráfego real.

3.1 Tabela de resultados

Teste	Resultado esperado (reportado pela página)	Resultado do plugin	Divergência e explicação
Tracker Reporting 1: via script	Carrega <code>doubleclick.net/tracker.js</code> ; o escudo do Firefox reporta "1 rastreador bloqueado".	<code>doubleclick.net</code> (script×1), 1 de 2 requisições; score 99.	Concorda. O plugin reporta mesmo com o Firefox bloqueando: o <code>onBeforeRequest</code> roda antes do cancelamento. Sem cookies porque a resposta não chega.
Tracker Reporting 2: surrogate	Carrega <code>doubleclick.net/instream/ad_status.js</code> .	<code>doubleclick.net</code> (script×1); score 99.	Concorda na detecção. O plugin não substitui scripts por <code>*surrogates*</code> : ele detecta, e só bloqueia pela lista.
Tracker Reporting 3: img	<code></code> .	<code>facebook.com</code> (image×1), 1 cookie persistente de 3ª parte ; score 97.	Concorda. O Firefox (modo Padrão) não bloqueou <code>facebook.com</code> : a resposta chegou com <code>Set-Cookie</code> .
Tracker Reporting 4: fetch	<code>fetch('https://facebook.com/tr?test=1')</code> ; página: "Tracker loaded".	<code>facebook.com</code> (xmlhttprequest×1), 1 cookie persistente; score 97.	Concorda.
Tracker Reporting 5: document fragment	<code></code> criado via fragmento de documento.	<code>facebook.com</code> (image×1), 0 cookies; score 99.	Detecção concorda. Sem cookie porque ele já existia (páginas 3 e 4): o plugin conta <code>Set-Cookie</code> recebido naquele carregamento.
Storage blocking	"Stored random number using 23 storage mechanisms" (1ª parte e iframes de 3ª parte).	3ª parte: <code>third-party.site</code> (20 req), <code>ad-company.site</code> (6). Cookies: 1 de 1ª + 8 de 3ª. HTML5: <code>localStorage</code> 1/3, <code>sessionStorage</code> 1/3, <code>IndexedDB</code> 1/2 (1ª/3ª).	Parcial: o plugin cobre <code>Set-Cookie</code> , <code>localStorage</code> , <code>sessionStorage</code> e <code>IndexedDB</code> . Cookies via <code>document.cookie</code> , <code>Cache API</code> , <code>service worker</code> e outros mecanismos da página estão fora do escopo.
Fingerprinting (canvas)	"Collected 124 datapoints"; testes <code>2d-todataurl</code> , <code>2d-imagedata</code> , <code>offscreen</code> e <code>WebGL</code> .	5 extrações de fingerprint por execução (<code>toDataURL</code> 2D×3, <code>getImageData</code> ×1, <code>WebGL</code> ×1), script <code>helpers/tests.js</code> ; score 90.	Concorda nos 4 testes de canvas, inclusive <code>OffscreenCanvas</code> → <code>ImageBitmap</code> → <code>drawImage</code> . Os demais 120 datapoints (<code>navigator</code> , <code>screen</code> , <code>audio</code> ...) não são objeto do plugin.
Bounce tracking: first-party.site	Passa por <code>bad.third-party.site</code> , que grava um ID e redireciona por JavaScript; com proteção, o ID não deveria persistir.	<code>bad.third-party.site</code> [bounce], redirect por JS após 354 ms, <code>localStorage:bounceUID</code> no salto; ID repassado : <code>isNew</code> (quando o ID tem ≥ 2 dígitos).	Concorda. Com ID de 1 dígito ("1"), o "ID repassado" não é mostrado: valores de 1 caractere são ignorados para evitar falsos positivos.
Bounce tracking: good.third-party.site	Mesmo bounce, destino <code>good.third-party.site</code> .	Cadeia mostrada e identificadores <code>bounceUIDlocalStorage/bounceUIDcookie</code> na URL, mas sem etiqueta bounce.	Diverge por projeto: <code>bad.</code> e <code>good.third-party.site</code> têm o mesmo eTLD+1 e já compartilham cookies; não é bounce entre sites.

Teste	Resultado esperado (reportado pela página)	Resultado do plugin	Divergência e explicação
Query parameters (4 links)	Com proteção: 1 → q=other; 2 → vazio; 3 → u=14; 4 → inalterado.	1: utm_source; 2: utm_source, utm_medium; 3: fbclid, fb_source; 4: nada sinalizado.	Classificação 4/4 igual à do DDG. A página mostra os parâmetros intactos porque o plugin detecta mas não remove (e o Firefox Padrão não remove).
Tracker Blocking (request-blocking)	A página pede para adicionar bad.third-party.site à lista; testa 23 mecanismos.	Sem lista: 22/23 carregaram. Com lista: nenhum carregou ; popup "22 requisições bloqueadas".	22 × 23: o serviceworker-fetch tem tabId -1; é bloqueado, mas não é atribuído à aba. O websocket já falhava sem bloqueio (servidor).
Storage partitioning	"Retrieved data from 21 storage mechanisms", same-site × cross-site.	Após correção: 21 mecanismos, 19 pass + WebSQL unsupported + Prefetch Cache error. Popup: chaves partition_test e sessionId na URL.	A 1ª versão do plugin quebrava esta página (ver 3.3). Prefetch Cache "error": cache de execuções anteriores (na janela privada deu pass).
js-leaks	Compara as globais de window com o perfil do Firefox 92 (Added/Removed/Changed).	2 globais adicionadas: collectedProps, results (criadas pelo teste); 0 nativas sobrescritas.	Concorda. As centenas de "Added" da página vêm da diferença Firefox 156 × 92, não do plugin.

3.2 Detalhamento por página

Tracker Reporting

As cinco páginas carregam um único rastreador "major" por mecanismos diferentes. O plugin reportou os cinco. No primeiro teste, o próprio Firefox (Proteção Aprimorada) bloqueou doubleclick.net, e mesmo assim a requisição apareceu no plugin, que a vê no instante em que é criada. Já facebook.com/tr não foi bloqueado no modo Padrão: a resposta chegou e o plugin registrou o cookie persistente.

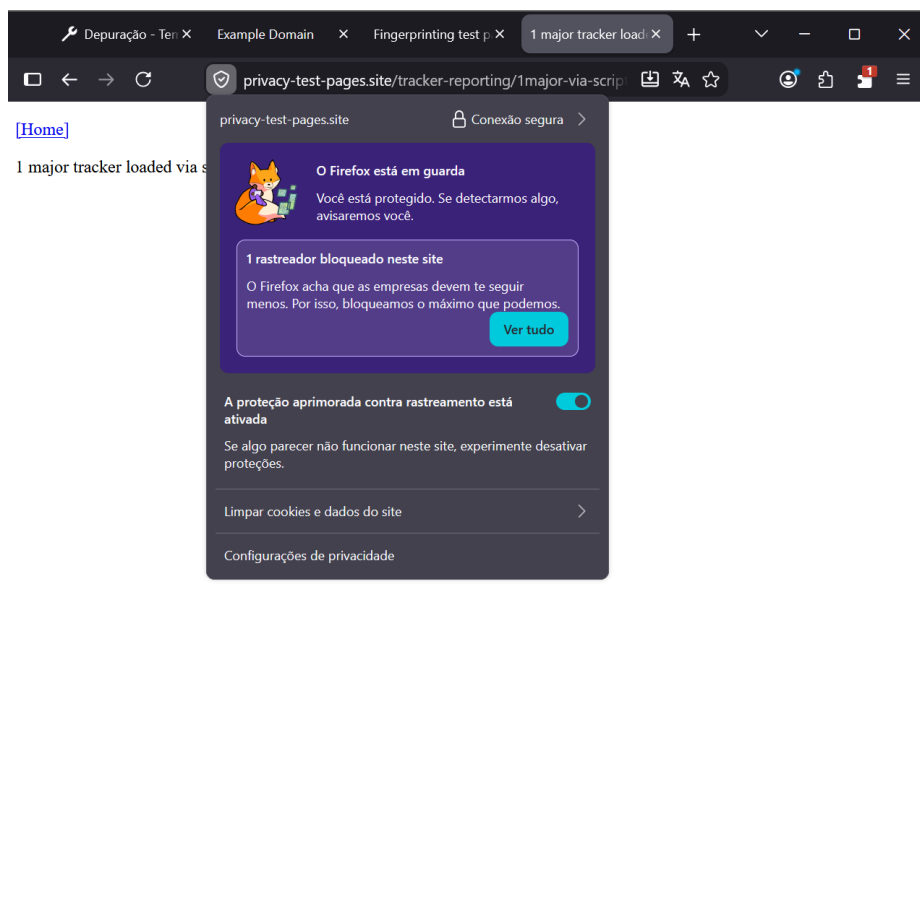


Figura 1 – Escudo do Firefox: "1 rastreador bloqueado neste site" na página via script (evidencias/ddg/tracker-reporting-1-script-firefox-etp.png)

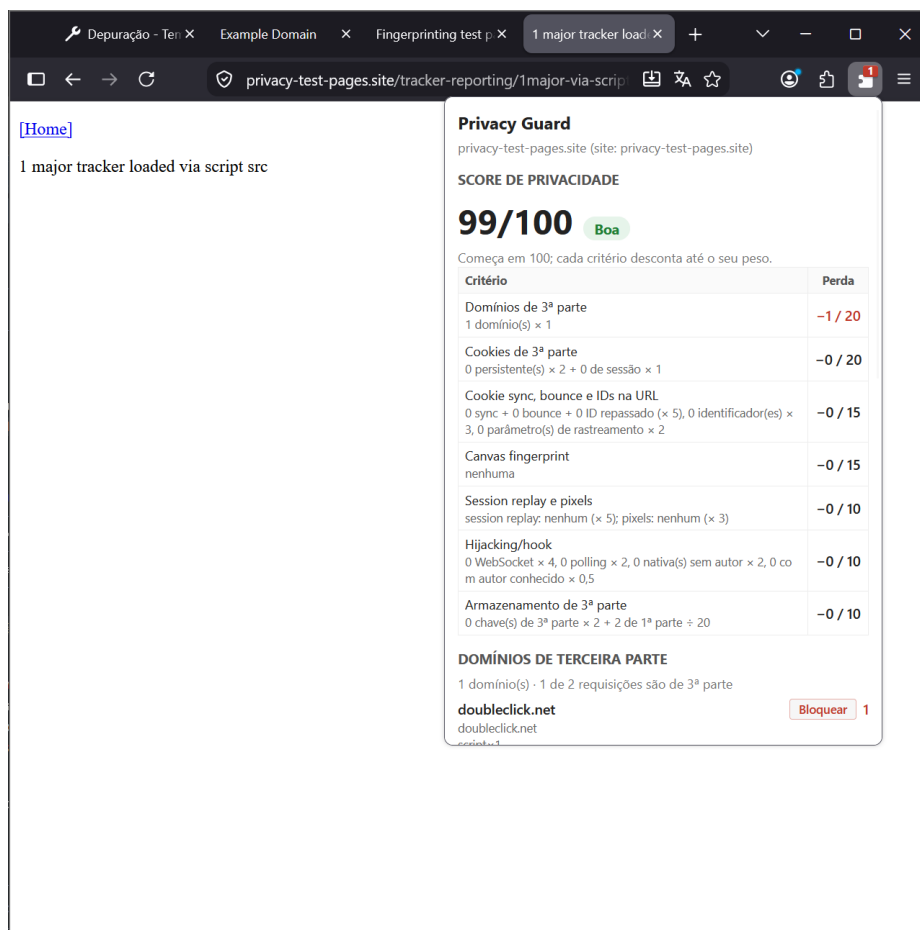


Figura 2 – Plugin na página via script: `doubleclick.net`, score 99/100 (evidencias/ddg/tracker-reporting-1-script.png)

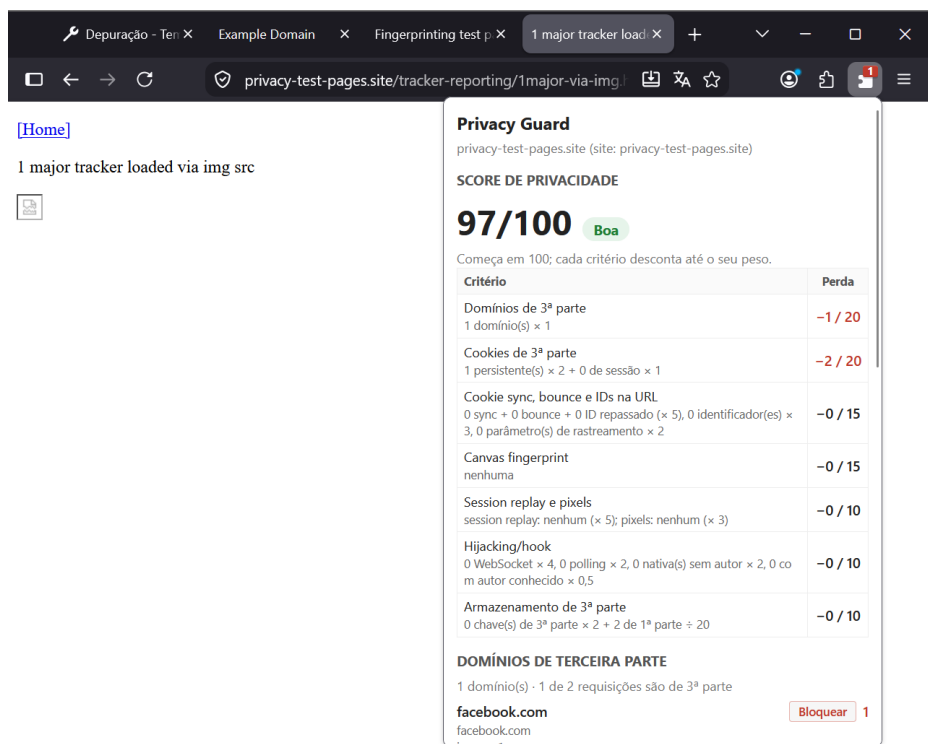


Figura 3 – Plugin na página via img: facebook.com e 1 cookie persistente de 3ª parte, score 97/100 (evidencias/ddg/tracker-reporting-3-img.png)

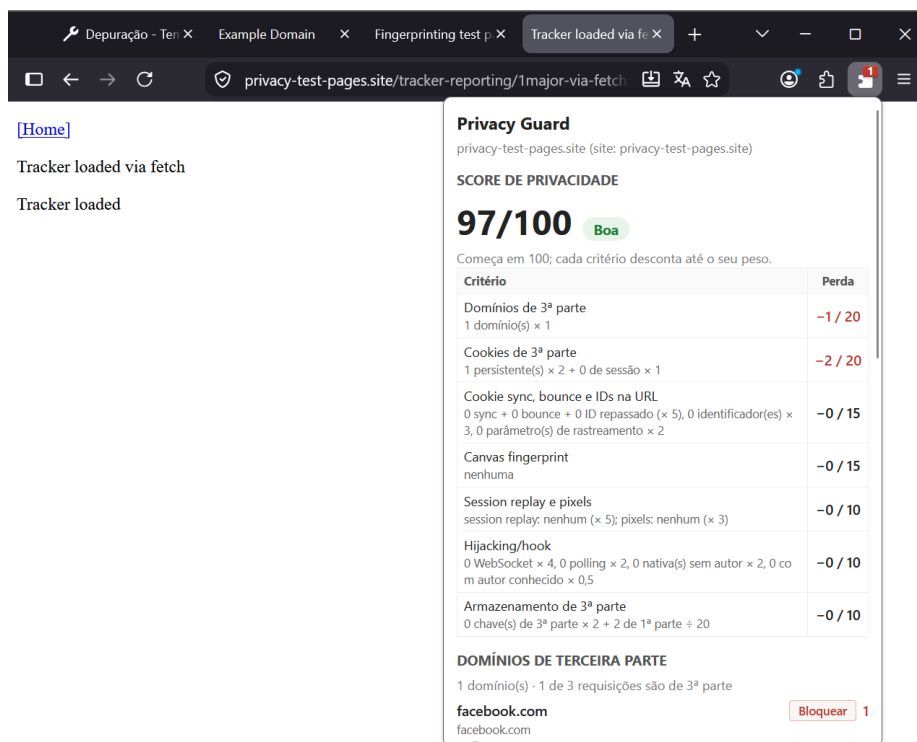


Figura 4 – Plugin na página via fetch ("Tracker loaded") (evidencias/ddg/tracker-reporting-4-fetch.png)

Os prints das páginas *surrogate* e *document fragment* estão em evidencias/ddg/tracker-reporting-2-surrogate.png e tracker-reporting-5-fragment.png.

Storage blocking

Ao clicar em *Store data*, a página grava um número aleatório em 23 mecanismos, na própria origem e em iframes de terceira parte. O plugin mostrou as chaves data gravadas em localStorage, sessionStorage e IndexedDB tanto em privacy-test-pages.site (1ª parte, gravadas por helpers/commonTests.js e helpers/idb-wrapper.js) quanto em good.third-party.site (iframe de 3ª parte), além de 8 cookies de 3ª parte recebidos por cabeçalho (*_tracker_headerdata, SameSite=None, HttpOnly).

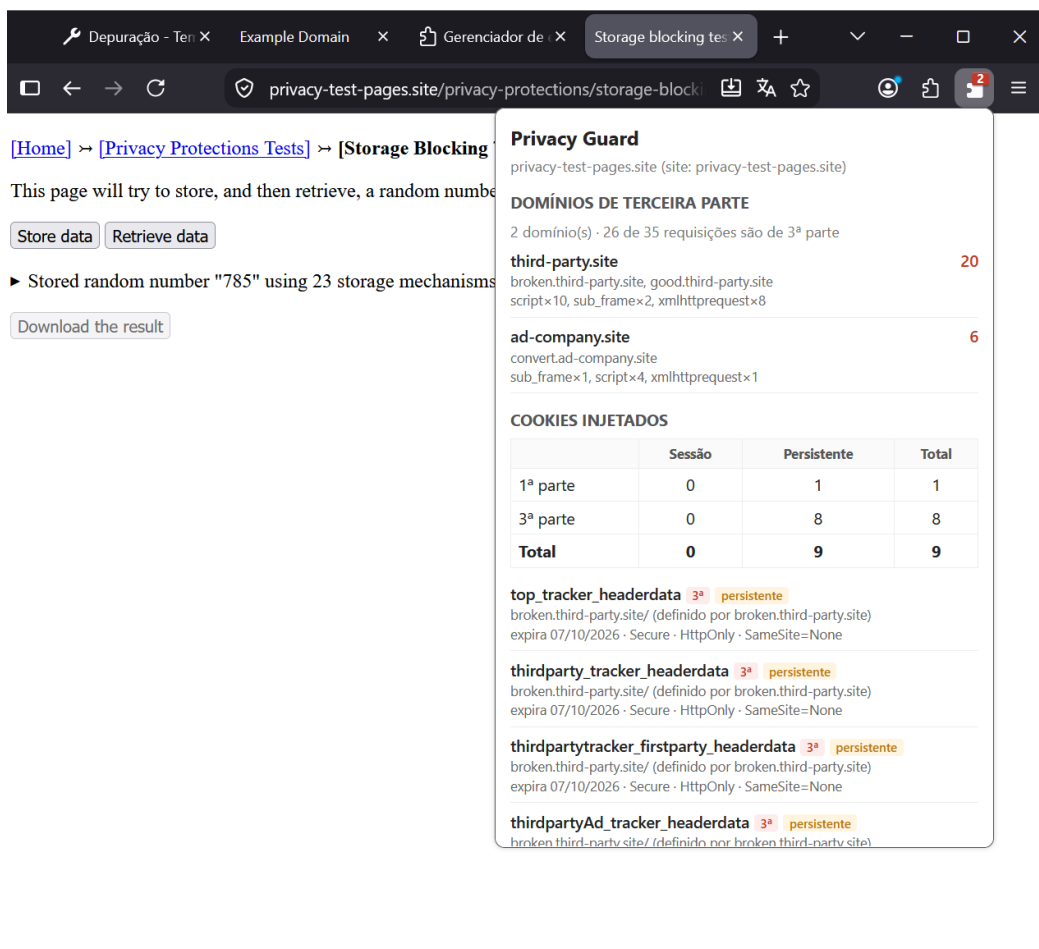


Figura 5 – Storage blocking: domínios e cookies de 3ª parte (evidencias/ddg/storage-blocking-1-terceira-parte-cookies.png)



Figura 6 – Storage blocking: armazenamento HTML5 por origem (1ª e 3ª parte) (evidencias/ddg/storage-blocking-2-html5.png)

Fingerprinting (canvas)

A página desenha a frase "Cwm fjordbank glyphs vext quiz, 🤖" em duas cores num canvas de 2000×200 e extrai os pixels por quatro caminhos. O plugin classificou todas as extrações como fingerprint e identificou o script responsável. O score da página foi 90, com perda apenas no critério de canvas.

Depuração - Te

Example Domain

Canvas Fingerpr

Fingerprinting test p

privacy-test-pages.site/privacy-protections/fingerprinting/

[\[Home\]](#) → [\[Privacy Protections Tests\]](#) → [\[Fingerprinting Te](#)

This page collects various datapoints from your browser that

⚠ Please note that:

- not all of the properties listed here have to be modified
- depending on the brower some properties may change i
- some data is duplicated, but it's retrieved using differen
- this page has to be loaded over https for all tests to wor

Start the test

- ☐ Include all headers and all properties of window, nav
- ☐ Collect information from events (you will have to i

► Collected 124 datapoints (14 failed). Click for details.

Download the result

Save result in localStorage

Compare current result with result from localStorage

Compare current result with result loaded from a file

Procura

► Canvas visual check

Total	0	0	0
-------	---	---	---

ARMAZENAMENTO HTML5

	1ª parte	3ª parte
localStorage	1	0
sessionStorage	0	0
indexedDB	1	0

https://privacy-test-pages.site 1ª

localStorage (1): data
indexedDB (1): data

BOUNCE TRACKING E COOKIE SYNC

0 salto(s) de bounce · 0 ID(s) repassado(s) · 0 parâmetro(s) de rastreamento · 0 identificador(es) na URL · 0 sincronização(ões)

CANVAS FINGERPRINT

10 tentativa(s) de fingerprint · 0 leitura(s) de canvas

https://privacy-test-pages.site/privacy-protections/fingerprinting/helpers/test.sjs

privacy-test-pages.site 1ª fingerprint

2

getImageData · 2000×200 · image/png
desenho: 29 caractere(s) distinto(s), 2 cor(es)
https://privacy-test-pages.site/privacy-protections/fingerprinting/helpers/test.sjs

privacy-test-pages.site 1ª fingerprint

2

toDataURL · 2000×200 · image/png
desenho: 0 caractere(s) distinto(s), 0 cor(es) · WebGL
https://privacy-test-pages.site/privacy-protections/fingerprinting/helpers/test.sjs

Figura 7 – Fingerprinting: extrações de canvas detectadas, com linha separada para WebGL (evidencias/ddg/fingerprinting-1-canvas.png)

Depuração - Tempo de e... Example Domain x Fingerprinting test page x + - □ ×

privacy-test-pages.site/privacy-protections/fingerprinting/

⚠ Please note that:

- not all of the properties listed here have to be modified
- depending on the browser some properties may change
- some data is duplicated, but it's retrieved using different methods
- this page has to be loaded over https for all tests to work

Start the test

- ☐ Include all headers and all properties of window, navigator and document
- ☐ Collect information from events (you will have to intercept them)

▼ Collected 124 datapoints (14 failed). Click for details.

headers

- headers - accept - (string) - "*/"
- headers - accept-encoding - (string) - "gzip, deflate"
- headers - accept-language - (string) - "pt-BR,pt-BR;q=0.9,en-US;q=0.8,en;q=0.7"
- headers - dnt - (undefined) - undefined
- headers - user-agent - (string) - "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/156.0"

navigator

- navigator.userAgent - (string) - "Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/156.0"
- navigator.deviceMemory - (undefined) - undefined
- navigator.hardwareConcurrency - (number) - 20
- navigator.product - (string) - "Gecko"
- navigator.productSub - (string) - "20100101"
- navigator.appName - (string) - "Netscape"
- navigator.appVersion - (string) - "5.0 (Windows)"
- navigator.appCodeName - (string) - "Mozilla"
- navigator.language - (string) - "pt-BR"
- navigator.languages - (array) - ["pt-BR", "pt", "en-US", "en"]
- navigator.platform - (string) - "Win32"
- navigator.vendor - (string) - ""
- navigator.vendorSub - (string) - ""
- navigator.mimeTypes - (object) - { "application/pdf": true, "text/pdf": true }
- navigator.cookieEnabled - (boolean) - true
- navigator.doNotTrack - (string) - "unspecified"
- navigator.maxTouchPoints - (number) - 0
- navigator.connection - ✖ error thrown - { "name": "TypeError", "message": "can't access property \"effectiveType\", navigator.connection is undefined", "stack": "getValue@https://privacy-test-pages.site/privacy-protections/fingerprinting/helpers/tests.js:143:13\nrunTests/@https://privacy-test-pages.site/privacy-protections/fingerprinting/main.js:96:32\nrunTests@https://privacy-test-pages.site/privacy-protections/fingerprinting/main.js:56:11\n@https://privacy-test-pages.site/privacy-protections/fingerprinting/main.js:254:45\nEventListener.handleEvent*@https://privacy-test-pages.site/privacy-protections/fingerprinting/main.js:254:13\n" }
- navigator.storage.estimate() - (object) - { "quota": 10737418240, "usage": 164428 }

Privacy Guard
privacy-test-pages.site (site: privacy-test-pages.site)

SCORE DE PRIVACIDADE

90/100 Boa

Começa em 100; cada critério desconta até o seu peso.

Critério	Perda
Domínios de 3ª parte 0 domínio(s) × 1	-0 / 20
Cookies de 3ª parte 0 persistente(s) × 2 + 0 de sessão × 1	-0 / 20
Cookie sync, bounce e IDs na URL 0 sync + 0 bounce + 0 ID repassado (× 5), 0 identificador(es) × 3, 0 parâmetro(s) de rastreamento × 2	-0 / 15
Canvas fingerprint 3 extração(ões) de fingerprint (1ª parte)	-10 / 15
Session replay e pixels session replay: nenhum (× 5); pixels: nenhum (× 3)	-0 / 10
Hijacking/hook 0 WebSocket × 4, 0 polling × 2, 0 nativa(s) sem autor × 2, 0 com autor conhecido × 0,5	-0 / 10
Armazenamento de 3ª parte 0 chave(s) de 3ª parte × 2 + 2 de 1ª parte ÷ 20	-0 / 10

DOMÍNIOS DE TERCEIRA PARTE
0 domínio(s) - 0 de 8 requisições são de 3ª parte

BLOQUEADOS NESTA PÁGINA
0 requisição(ões) bloqueada(s) pela lista personalizada

Figura 8 – Fingerprinting: score 90/100, -10 no critério de canvas (evidencias/ddg/fingerprinting-2-score.png)

Bounce tracking

O link passa por `bad.third-party.site/.../bounce.html`, que gera um ID, grava em `localStorage` e cookie e redireciona por `location.href` para o destino com o ID na URL (`bounceUIDlocalStorage`, `bounceUIDcookie`, `isNew`). O plugin montou a cadeia de navegação, marcou o salto como bounce quando o destino era outro site e mostrou o ID repassado comparando o valor gravado no salto com os parâmetros da URL final.

Depuração - Ter

Example Domain

Bounce Tracking Tes

Bounce Tracking Tes

good.third-party.site/privacy-protections/bounce-tracking

[\[Home\]](#)
[\[Privacy Protections Tests\]](#)
[\[Bounce Tracking\]](#)

Below links allow to bounce of bad.third-party.site to different destination via URL param.

[Go to good.third-party.site](#)

[Go to first-party.site](#)

[Go to privacy-test-pages.site](#)

[Go to www.publisher-company.site](#)

ID didn't exist and was generated - "21".

good.third-party.site (site: third-party.site)

DOMÍNIOS DE TERCEIRA PARTE

0 domínio(s) · 0 de 1 requisições são de 3ª parte

COOKIES INJETADOS

	Sessão	Persistente	Total
1ª parte	0	0	0
3ª parte	0	0	0
Total	0	0	0

ARMAZENAMENTO HTML5

	1ª parte	3ª parte
localStorage	0	0
sessionStorage	0	0
indexedDB	0	0

BOUNCE TRACKING E COOKIE SYNC

1 salto(s) de bounce · 1 ID(s) repassado(s) · 0 parâmetro(s) de rastreamento · 0 identificador(es) na URL · 0 sincronização(ões)

Cadeia de navegação

privacy-test-pages.site bounce → redirect por JavaScript após 3867 ms
gravou: localStorage:data, indexedDB:data
bad.third-party.site → redirect por JavaScript após 364 ms
gravou: localStorage:bounceUID
good.third-party.site (destino)

ID repassado pela URL

isNew = valor de localStorage:bounceUID gravado por bad.third-party.site

Figura 10 – Bounce para good.third-party.site: "ID repassado pela URL: isNew" (ID gerado "21") (evidencias/ddg/bounce-tracking-2-good-third-party-id-repassado.png)

Query parameters

The screenshot shows a web browser with the address bar displaying `privacy-test-pages.site/privacy-protections/query-parameters/`. The page content includes a breadcrumb trail: [\[Home\]](#) → [\[Privacy Protections Tests\]](#) → [\[Query Parameters\]](#). Below this, it states: "This page is a landing page for the query parameters tests. It is a test page for the query parameters tests." The "Results" section shows the query string: `"fbclid=12345&fb_source=something&u=14"`. A "Privacy Guard" overlay is visible on the right side of the page, displaying the following information:

Privacy Guard
privacy-test-pages.site (site: privacy-test-pages.site)

DOMÍNIOS DE TERCEIRA PARTE
0 domínio(s) · 0 de 2 requisições são de 3ª parte

COOKIES INJETADOS

	Sessão	Persistente	Total
1ª parte	0	0	0
3ª parte	0	0	0
Total	0	0	0

ARMAZENAMENTO HTML5

	1ª parte	3ª parte
localStorage	1	0
sessionStorage	0	0
indexedDB	1	0

https://privacy-test-pages.site 1ª

localStorage (1): data
indexedDB (1): data

BOUNCE TRACKING E COOKIE SYNC
0 salto(s) de bounce · 0 ID(s) repassado(s) · 2 parâmetro(s) de rastreamento · 0 identificador(es) na URL · 0 sincronização(ões)

Parâmetros na URL da página
`fbclid` `fb_source`
laranja = rastreamento de campanha/clique · vermelho = identificador

Figura 11 – Link 3: `fbclid` e `fb_source` sinalizados como parâmetros de rastreamento (evidencias/ddg/query-parameters-3.png)

Os quatro links estão em evidencias/ddg/query-parameters-1.png a -4.png. No link 4 (`q=something&id=1234`) nada é sinalizado, o que bate com o DDG, que não considera `id` um parâmetro de rastreamento.

Tracker Blocking (request-blocking)

Depuração - Ten x Example Domain x Detect changes to JS x Request blockin: x + - □ ×

privacy-test-pages.site/privacy-protections/request-blockin

[Home] → [Privacy Protections Tests] → [Request Blocking Test Page]

This page tests if different types of requests, made using various browser mechanisms, are getting blocked.

To test your request blocking solution please add bad.third-party.site domain to your blocklist.

Start the test Download the results

- HTML
 - - script - Try loading a JavaScript file using <script> element.
 - - style - Try loading a CSS file using <link> element.
 - - img - Try loading an image using element.
 - - picture - Try loading an image using <picture> element.
 - - object - Try loading an image using <object> element.
 - - audio - Try loading an audio file using <audio> element.
 - - video - Try loading a video file using <video> element.
 - - iframe - Try loading a frame using <iframe> element.
- CSS
 - - import - Try loading a CSS file using @import url(...).
 - - font - Try loading a font file using @font-face {src: url(...)}.
 - - background - Try loading an image using background: url(...).
- JS
 - - websocket - Try connecting to a WebSocket.
 - - server-sent-events - Try connecting to an EventSource.
 - - fetch - Try requesting data using fetch(...).
 - - xmlhttprequest - Try requesting data using XMLHttpRequest.
 - - sendBeacon - Try sending data using sendBeacon.
- Other
 - - favicon - Try loading an image using <link rel="shortcut icon"
 - - iframe-fetch - Try requesting data from within a first-party iframe.
 - - iframe-fetch-depth-2 - Try requesting data from two frames deep (iframe within an iframe).
 - - webworker-fetch - Try fetching data from within a WebWorker.
 - - serviceworker-fetch - Try fetching data from within a ServiceWorker.
 - - csp-report - Try sending data via CSP report.
 - - redirected-fetch - Try requesting tracker via redirect through a safe domain.

Legend:

- - request has loaded
- - request hasn't loaded
- - request failed (e.g. due to being blocked)

Figura 12 – Sem lista de bloqueio: 22 de 23 mecanismos carregam (verde) (evidencias/ddg/tracker-blocking-1-sem-lista-pagina.png)

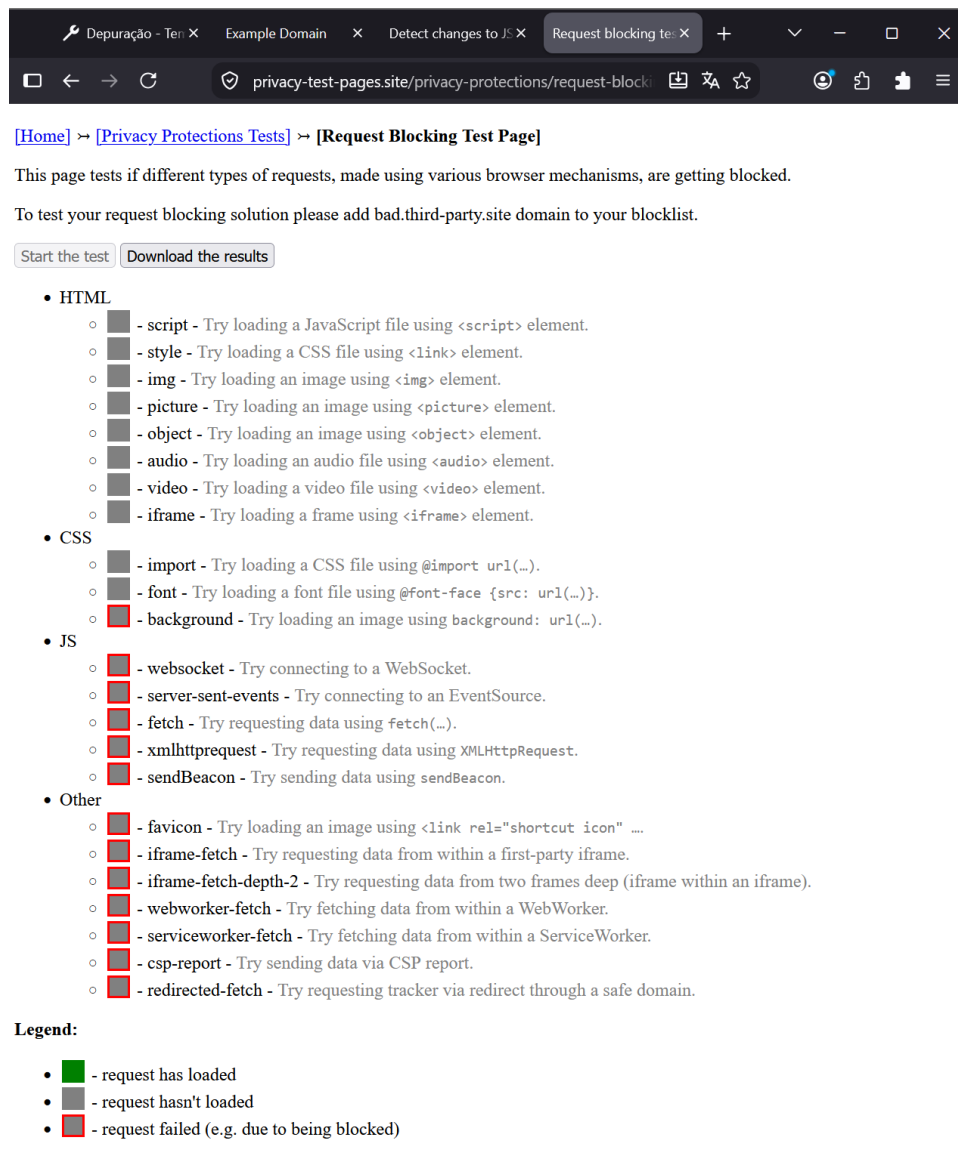


Figura 13 – Com bad.third-party.site na lista: nenhum mecanismo carrega (evidencias/ddg/tracker-blocking-3-com-lista-pagina.png)

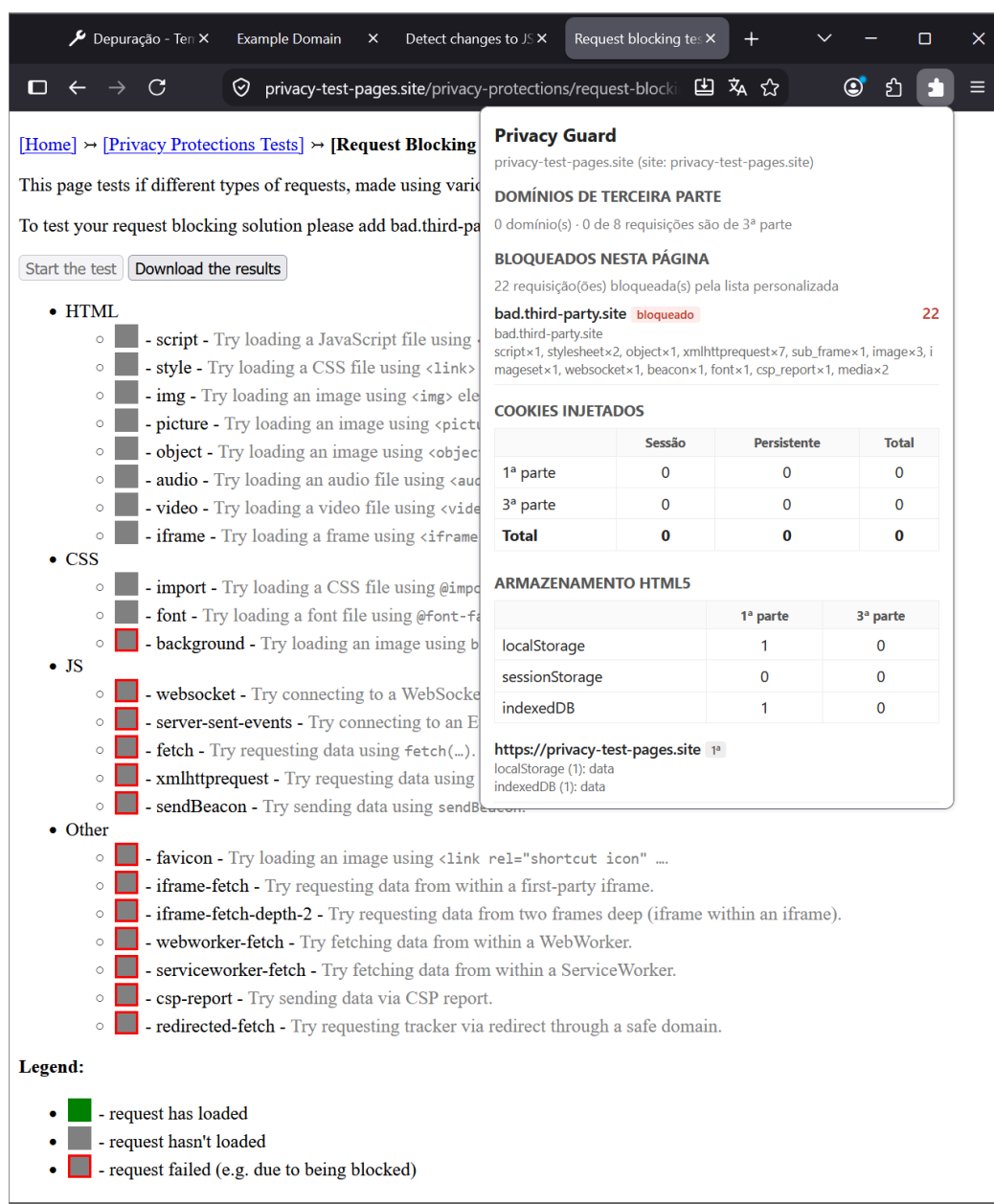


Figura 14 – Popup: 22 requisições bloqueadas pela lista personalizada (evidencias/ddg/tracker-blocking-4-com-lista-popup.png)

Storage partitioning

A página grava um ID de sessão e abre uma aba de teste que navega entre `www.first-party.site` e `good.third-party.site`, embutindo um `iframe` que tenta ler o ID. Com a versão final do plugin, a página obteve os 21 mecanismos: o `iframe` cross-site não enxerga os dados de 1ª parte (`null` ou valor novo), o que mostra o particionamento de estado do Firefox (Total Cookie Protection). O item 3.3 descreve como esta página revelou um defeito da extensão.

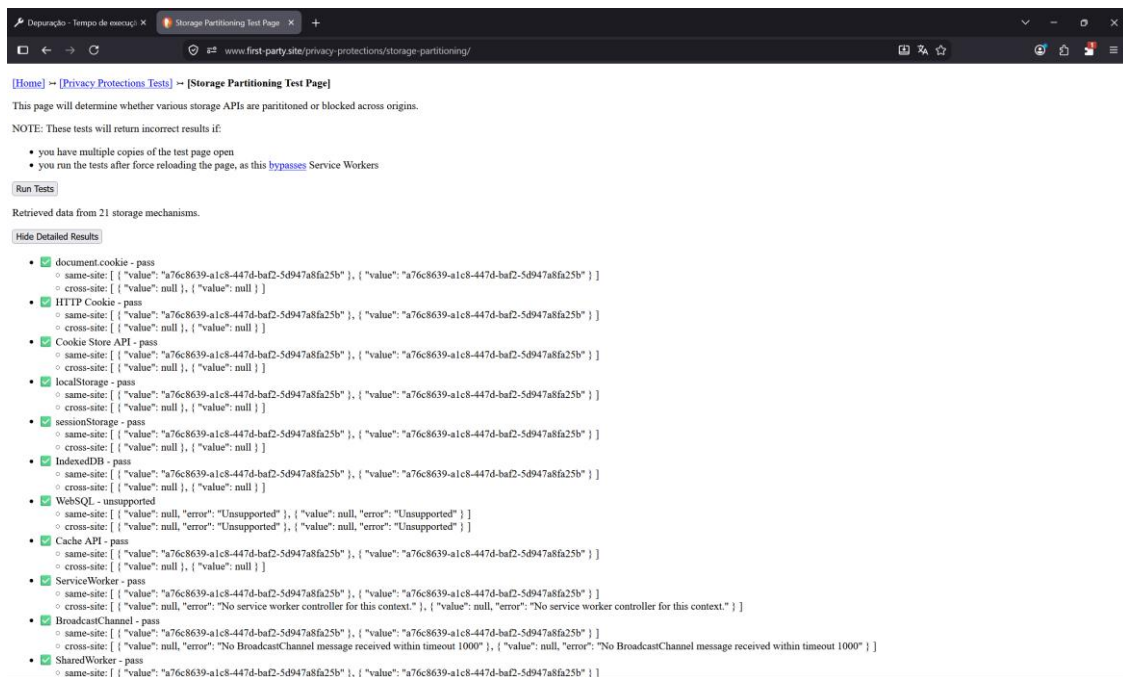


Figura 15 – Storage partitioning com a extensão corrigida: 21 mecanismos (evidencias/ddg/storage-partitioning-com-extensao-1.png)

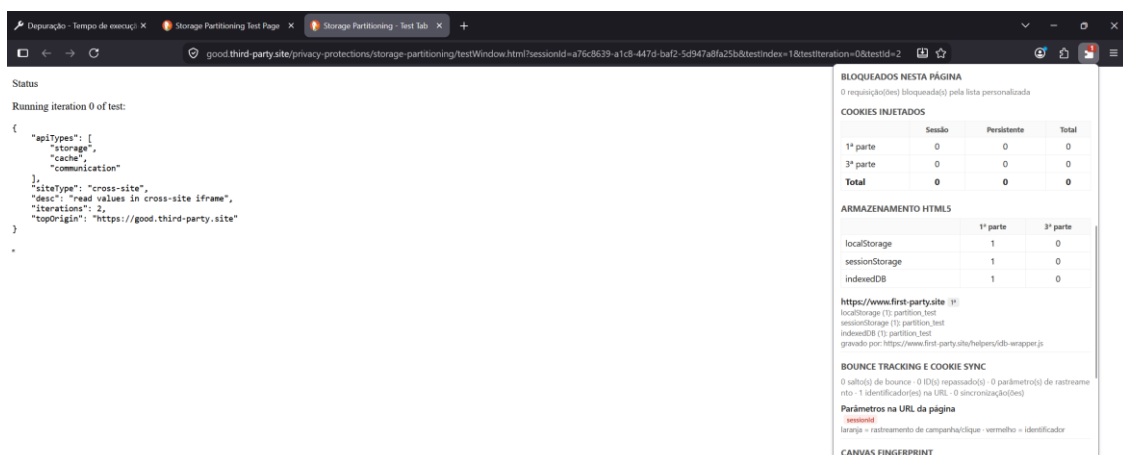


Figura 16 – Popup na aba de teste: chaves partition_test e sessionId como identificador na URL (evidencias/ddg/storage-partitioning-aba-de-teste-popup.png)

js-leaks

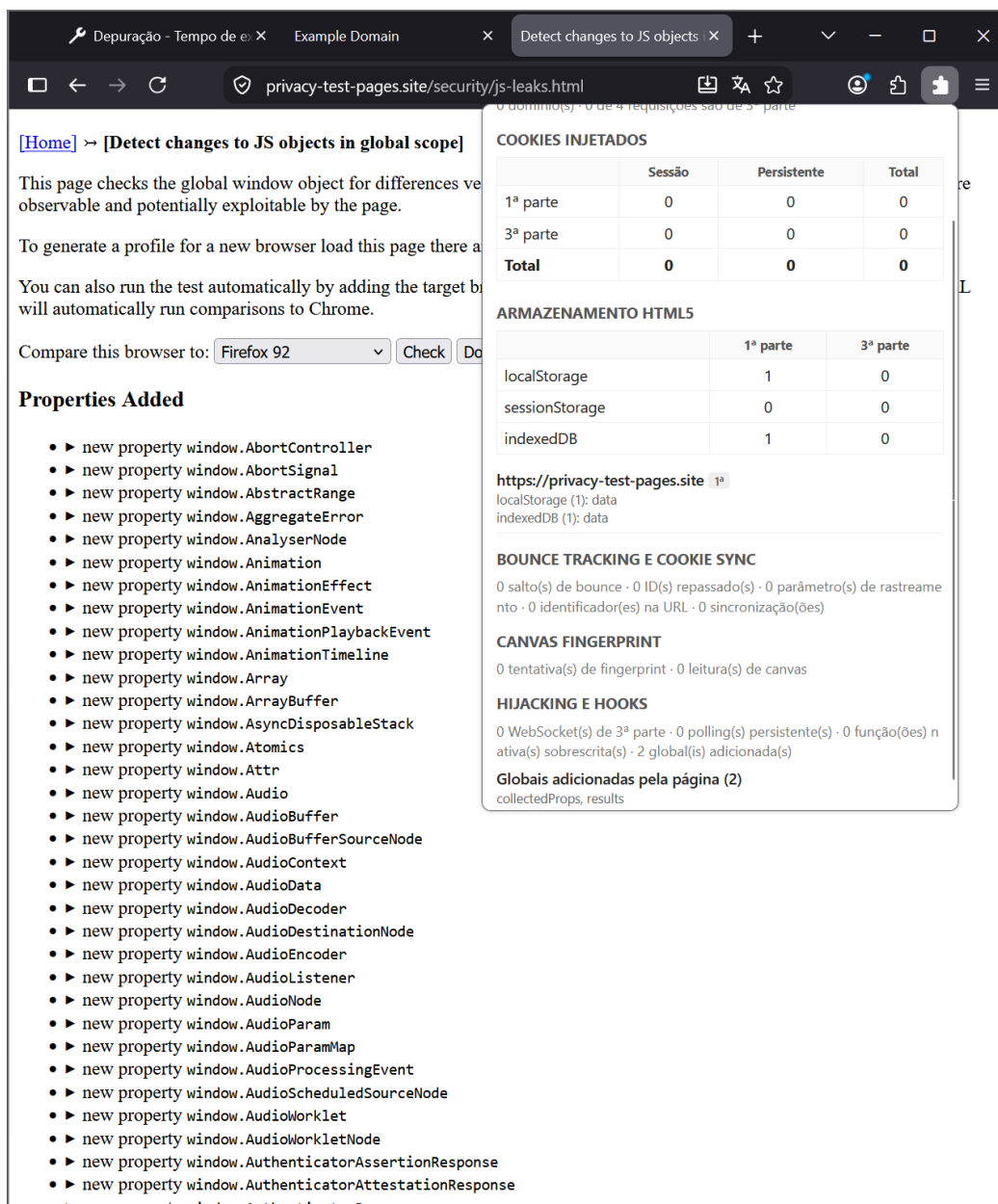


Figura 17 – js-leaks: o plugin detecta as globais `collectedProps` e `results` criadas pelo teste (evidências/ddg/js-Leaks.png)

A página lista centenas de propriedades como "adicionadas" porque compara o Firefox 156 com um perfil do Firefox 92 (APIs novas). Pelo código da página, os hooks do plugin sobre `localStorage.setItem` e `indexedDB.open` são observáveis na seção `*Changed*` (o `toString()` deixa de ser `[native code]`): é a pegada da extensão. Por isso ela não substitui construtores globais (`fetch`, `WebSocket`), que alterariam o ambiente que ela mesma avalia.

3.3 Defeitos revelados pelos testes e correções

Os testes nas páginas do DDG e em sites reais revelaram defeitos que só apareceriam em uso real. Cada um foi diagnosticado a partir do tráfego ou do código da página e corrigido:

Onde apareceu	Sintoma	Causa e correção
example.com.	Popup mostrava "site: com."	Hostname em forma FQDN (ponto final) deslocava o cálculo do eTLD+1. O ponto final passou a ser removido.
Bounce (1ª versão)	O ID do bounce aparecia no storage do destino, e não no salto	Condição de corrida: a página grava e redireciona na hora, e o evento chegava depois da nova navegação. Eventos do frame principal de outro host passaram a ser atribuídos ao salto.
Bounce, 1ª visita	"0 identificadores"; o ID ia em isNew	Deteção só pelo nome do parâmetro. Passou a comparar o valor gravado no salto com os parâmetros da URL.
Bounce	A página índice aparecia como bounce	Clique do usuário em < 5 s confundido com redirect automático. O content.js passou a registrar pointerdown/keydown confiáveis.
BrowserLeaks	0 detecções de canvas	O canvas era criado dentro de um iframe (protótipos sem hooks), uma técnica de evasão. Os hooks passaram a ser instalados nas janelas de iframes ao acessar contentWindow/contentDocument.
g1 (polling)	38 "pollings" com intervalo ~0 s	Rajadas de leilão contadas como polling. Passou a agrupar em rodadas (gap ≤ 2 s) e exigir ≥ 4 rodadas.
g1 (score)	Meta Pixel contado duas vezes (fbq, _fbq)	Contagem passou a ser por fornecedor.
Tracker Blocking	serviceworker-fetch passaria	Requisições com tabId -1 eram descartadas antes da lista. A lista passou a valer para qualquer requisição.
Storage partitioning	TypeError: retrieval.forEach is not a function; funcionava numa janela sem a extensão	A página aceita a primeira mensagem postMessage que chega, e o plugin usava postMessage internamente. Canal trocado por CustomEvent com nome secreto; a página não recebe mais mensagens da extensão.

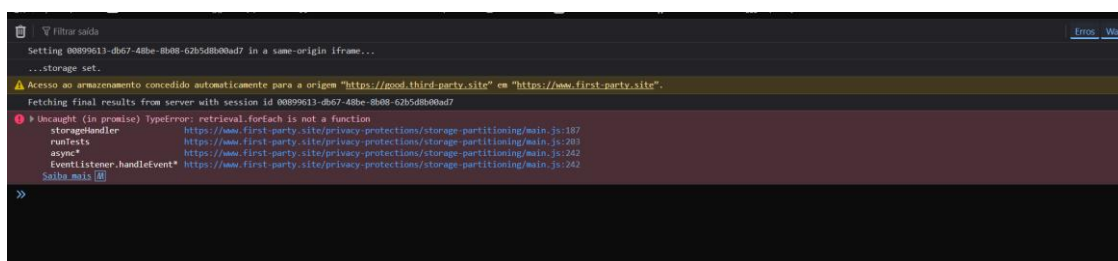


Figura 18 – Console com o erro causado pela 1ª versão da extensão (evidencias/ddg/storage-partitioning-erro-console.png)

4. Entregável 3: análise de 3 sites reais

Foram escolhidos três sites com níveis diferentes de rastreamento: um portal de notícias (**g1.globo.com**), um e-commerce (**mercadolivre.com.br**) e um site de controle (**pt.wikipedia.org**).

4.1 Procedimento de coleta

1. uBlock Origin **desligado** e lista de bloqueio do plugin vazia; usuário não logado; banners de consentimento **não** aceitos.
2. DevTools → Rede com "Persistir logs" e "Desativar cache"; carregamento do site; espera de 1 minuto; "Salvar tudo como HAR".
3. Na mesma aba e no mesmo carregamento, prints do popup do plugin (score, 3ª parte, cookies, storage, bounce/sync, canvas, hijacking).
4. Varredura no Blacklight (themarkup.org/blacklight) e prints do resultado.
5. uBlock Origin ligado, recarregamento do site e prints da lista de domínios bloqueados/permitidos.

Os números do plugin são ligeiramente maiores que os do HAR porque o popup foi aberto depois do "Salvar", com a página ainda carregando anúncios.

4.2 Visão geral

Métrica	g1.globo.com	mercadolivre.com.br	pt.wikipedia.org
Requisições no HAR	597	216	36
eTLD+1 de 3ª parte (HAR)	88	10	1
Set-Cookie no HAR (3ª parte)	274 (238)	41 (32)	31 (Wikimedia)
Redirects 302 no HAR	61	0 (1×301)	1
Plugin: domínios de 3ª parte	87	10	1
Plugin: cookies de 3ª parte	67 (65 persistentes)	9 (persistentes)	10 (9 persistentes)
Plugin: cookie syncs	82 a 120	0	0
Plugin: pollings de 3ª parte	23	2	0
Plugin: session replay / pixel	Microsoft Clarity / Meta Pixel	Hotjar / —	— / —
Score do plugin	17 (Crítica)	57 (Ruim)	80 (Moderada)
Blacklight: ad trackers / cookies 3ª	27 / 14	0 / 3	0 / 4
uBlock: bloqueios / domínios conectados	89 (16%) / 10 de 27	40 (9%) / 8 de 10	0 (0%) / 2 de 2

4.3 g1.globo.com

HAR

Item	Valor
Arquivo	evidencias/sites/site1-g1/site1-g1.har (50,7 MB)
Requisições	597; status 200×396, 204×106, 302×61 , 0×22, 202×4, 404×2

Item	Valor
Domínios	89 eTLD+1, 88 de 3ª parte. Mais requisitados: glbimg.com 96, globo.com 52, googlesyndication.com 37, doubleverify.com 37, g.globo 34, smartadserver.com 30, criteo.com 26, google.com 25, doubleclick.net 24, rubiconproject.com 23, adnxs.com 21, newsroom.bi 18, pubmatic.com 13
Cookies	274 Set-Cookie, 238 em respostas de 3ª parte
Endpoints de cookie sync	match.adsrvr.org, csync.smartadserver.com, rtb-csync.smartadserver.com, sync.crowdctrl.net, ups.analytics.yahoo.com, u.openx.net, ad.turn.com, image6.pubmatic.com, gum.criteo.com, cm.g.doubleclick.net

Resultado do plugin

Score **17/100 (Crítica)**, com teto atingido em domínios, cookies, sincronização, hijacking e armazenamento. Destaques:

- **87 domínios de 3ª parte** (91% das requisições); doubleverify.com com 149 requisições, sendo 96 beacon (verificação contínua de visibilidade de anúncios).
- **67 cookies de 3ª parte**, 65 persistentes, por exemplo uid (adform.net, SameSite=none), admtr/ac_r (admanmedia.com), uuid2 (adnxs.com).
- **Cookie sync**: o valor dos cookies glb_uid e hsid de globo.com aparece em URLs de ab.g.globo e mab.g.globo (domínios da própria Globo) e, principalmente, **hsid é enviado 28 a 30 vezes a securepubads.g.doubleclick.net**: identificador de 1ª parte compartilhado com o Google Ad Manager.
- **Pollings**: events.newsroom.bi/ingest.php a cada ~15 s, tpssc-ue1.doubleverify.com/event.png a cada ~5 s, i.clarity.ms/collect a cada ~16 s (gravação de sessão), prg.smartadserver.com/prebid/v1.
- **7 funções nativas sobrescritas** (fetch, setTimeout, setInterval, XMLHttpRequest.open/send, addEventListener, Function.prototype.toString), 5 atribuídas ao **Sentry**. Uso legítimo (monitoramento de erros), mas tecnicamente igual a um hook: quem controla os wrappers vê o tráfego e os eventos da página.
- Storage de 1ª parte com IDs de parceiros: _pubcid (Prebid), cto_bundle (Criteo), _lc2_fpi (LiveIntent), permutive-*, _gcl_ls (Google Ads).

Privacy Guard
g1.globo.com (site: globo.com)

SCORE DE PRIVACIDADE
17/100 Crítica

Começa em 100; cada critério desconta até o seu peso.

Critério	Pêda
Domínios de 3ª parte 87 domínios(s) × 1	-20 / 20
Cookies de 3ª parte 65 persistentes(s) × 2 + 2 de sessão × 1	-20 / 20
Cookie sync, bounce e IDs na URL 0 (trackers) × 4, 23 (polling) × 2, 2 (native) sem autor = 2, 5 c om autor conhecido = 0.5	-15 / 15
Canvas fingerprint nenhuma	-0 / 15
Session replay e pixels session replay: Microsoft Clarity (x 3); pixels: Meta Pixel (x 3)	-8 / 10
Hijacking/hoax 0 (trackers) × 4, 23 (polling) × 2, 2 (native) sem autor = 2, 5 c om autor conhecido = 0.5	-10 / 10
Armazenamento de 3ª parte 2 chaves(s) de 3ª parte × 2 + 129 de 1ª parte × 20	-10 / 10

DOMÍNIOS DE TERCEIRA PARTE
87 domínios(s) - 1074 de 1162 requisições são de 3ª parte

g1bing.com
s3.g1bing.com, s3.g1bing.com, s2-g1-g1bing.com

Bloquear 167

ROBERTO CARLOS
SANTOS-SP
31 OUTUBRO 20H30
SANTOS CONVENTION CENTER
VENDAS eventim

Nunes Marques reclama a Fachin de interferência indevida após Dino derrubar decisão do TSE e vê 'erosão democrática'
Presidente do tribunal enviou ofício ao chefe da Corte. Dino mandou restabelecer post sobre Nossa Senhora Aparecida derrubado por ordem de André Mendonça.

Polícia Investiga
VÍDEO: bebê de 1 ano e 6 meses foge da creche e anda até trabalho da mãe em SC

Entre Andes e Pacífico

Figura 20 – g1: score 17/100 (Crítica) (evidencias/sites/site1-g1/1-score.png)

BLOQUEADOS NESTA PÁGINA
0 requisições bloqueadas(s) pela lista personalizada

COOKIES INJETADOS

	Sessão	Persistente	Total
1ª parte	0	3	3
3ª parte	2	65	67
Total	2	68	70

uid 3ª persistente
adidm.net/ (definido por c1.adidm.net)
expira 27/11/2026 - Secure - SameSite=None

admtr 3ª persistente
admanmedia.com/ (definido por cs.admanmedia.com)
expira 05/10/2026 - Secure - HttpOnly - SameSite=None

ac7 3ª persistente
admanmedia.com/ (definido por cs.admanmedia.com)
expira 05/10/2026 - Secure - HttpOnly - SameSite=None

uid2 3ª persistente
adman.com/ (definido por cs.adman.com)

ARMAZENAMENTO HTML5

	1ª parte	3ª parte
localStorage	111	1
sessionStorage	13	1
IndexedDB	5	0

Casa de novela?

Chá Branco

Nunes Marques reclama a Fachin de interferência indevida após Dino derrubar decisão do TSE e vê 'erosão democrática'
Presidente do tribunal enviou ofício ao chefe da Corte. Dino mandou restabelecer post sobre Nossa Senhora Aparecida derrubado por ordem de André Mendonça.

Polícia Investiga
VÍDEO: bebê de 1 ano e 6 meses foge da creche e anda até trabalho da mãe em SC

Entre Andes e Pacífico

Figura 21 – g1: cookies injetados (67 de 3ª parte) (evidencias/sites/site1-g1/3-cookies.png)



Figura 22 – g1: cookie sync (hsid → securepubads.g.doubleclick.net) e polls (evidencias/sites/site1-g1/5-sync-canvas-hijacking.png)

Demais prints: 2-terceira-parte.png, 4-storage-e-cookie-sync.png e 6-hijacking-polling.png, na mesma pasta.

Blacklight

A varredura foi feita com device=mobile&location=us-ca (celular, Califórnia, navegador headless). Resultado: **27 ad trackers**, **14 cookies de 3ª parte**, "tells X" e Google Analytics remarketing encontrados; fingerprint, session recording, keystrokes, Facebook Pixel e TikTok Pixel não encontrados.

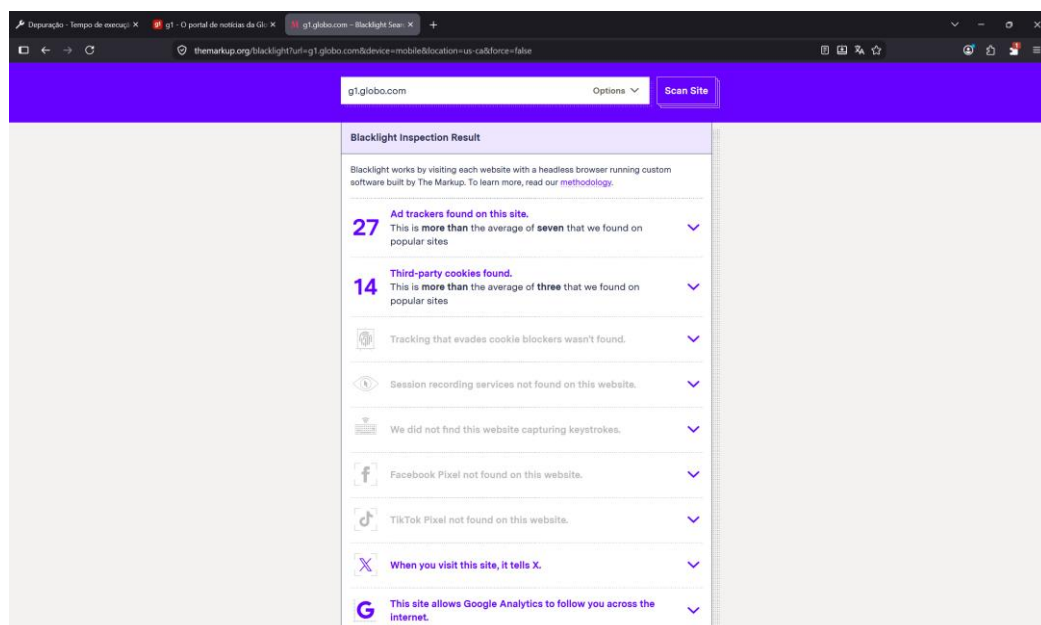


Figura 23 – Blacklight no g1: resumo (evidencias/sites/site1-g1/7-blacklight-resumo.png)

g1.globo.com
Options
Scan Site

Blacklight Inspection Result

Blacklight works by visiting each website with a headless browser running custom software built by The Markup. To learn more, read our [methodology](#).

27

Ad trackers found on this site.

This is **more than** the average of **seven** that we found on popular sites

Websites containing advertising tracking technology load JavaScript code or small invisible images that are used to either build your advertising profile or to identify you for ad targeting on this site. These techniques are often used in addition to cookies to profile you.

Blacklight detected trackers on this page sending data to companies involved in online advertising. Blacklight detected scripts belonging to **DoubleVerify**, **Twitter, Inc.**, **RTB House S.A.**, **Adform A/S**, **Criteo SA**, **Verizon Media**, **The Trade Desk Inc**, **OpenX Technologies Inc**, **PubMatic, Inc.**, **Smartadserver S.A.S**, **Livelihood Inc.**, **Alphabet, Inc.**, **Amobee, Inc**, **Magnite, Inc.**, **Microsoft Corporation**, **ID5 Technology Ltd**, **Lotame Solutions, Inc.**, and **Facebook, Inc.**

[How We Define This](#) [Survey of Popular Websites](#)

14

Third-party cookies found.

This is **more than** the average of **three** that we found on popular sites

These are commonly used by advertising tracking companies to profile you based on your internet usage.

Blacklight detected **14** third-party cookies on this site. Blacklight detected cookies set for **Livelihood Inc.**, **Twitter, Inc.** and **Criteo SA**, **Alphabet, Inc.**, and **Livelihood Inc.**

[How We Define This](#) [Survey of Popular Websites](#)



Tracking that evades cookie blockers wasn't found.

Figura 24 – Blacklight no g1: empresas dos ad trackers e cookies (evidencias/sites/site1-g1/8-blacklight-trackers-cookies.png)

Reconciliação Blacklight × HAR × plugin

As 18 empresas listadas pelo Blacklight foram procuradas no HAR. Como o plugin observa o mesmo tráfego, o que está no HAR aparece na lista de 3ª parte do plugin.

Empresa (Blacklight)	No HAR	Dominios observados
DoubleVerify	37	tps., tpssc-ue1., pub., cdn.doubleverify.com
Twitter (X)	5	analytics.twitter.com, static.ads-twitter.com, t.co
RTB House	0	— (ver abaixo)
Adform	1	c1.adform.net
Criteo	26	gum., grid-bidder., dis., ag.gbc.criteo.com
Verizon Media (Yahoo)	1	ups.analytics.yahoo.com
The Trade Desk	1	match.adsrvr.org

Empresa (Blacklight)	No HAR	Domínios observados
OpenX	8	u., us-u., eu-u.openx.net
PubMatic	13	hbopenbid., ads., ut., image6.pubmatic.com
Smartadserver	30	csync., prg., rtb-csync.smartadserver.com
LiveIntent	8	i., idx., rp.liadm.com
Alphabet (Google)	95	doubleclick.net, googlesyndication.com, analytics.google.com, googletagmanager.com
Amobee	1	ad.turn.com
Magnite	23	fastlane., prebid-a., ads.rubiconproject.com
Microsoft	7	scripts., i., www.clarity.ms
ID5	8	id5-sync.com
Lotame	2	sync.crowdctrl.net
Facebook (Meta)	3	connect.facebook.net, www.facebook.com

- **RTB House ausente no HAR:** o anúncio é decidido em leilão (header bidding), cujo vencedor muda a cada carregamento e depende de país e dispositivo. O Blacklight carregou a versão mobile a partir dos EUA.
- **27 ad trackers × 87 domínios:** o Blacklight conta rastreadores de anúncio de listas conhecidas; o plugin conta todo eTLD+1 diferente da página, inclusive a CDN e as métricas da própria Globo (glbimg.com, g.globo, cloud.globo). Critério diferente, não erro.
- **14 × 67 cookies:** o Blacklight conta os cookies que ficaram no navegador headless numa visita dos EUA; o plugin conta cada Set-Cookie de 3ª parte recebido (o HAR tem 238). Parceiros de sincronização do leilão brasileiro não aparecem na varredura americana.
- **Session recording** (Blacklight: não; plugin: Microsoft Clarity): o HAR confirma scripts.clarity.ms e 32 envios a i.clarity.ms/collect. O teste do Blacklight procura a gravação acontecendo durante a varredura; o plugin marca a presença do script (global clarity) e mostra o polling de coleta.
- **Facebook Pixel** (Blacklight: não; plugin: Meta Pixel): o HAR tem connect.facebook.net (script do pixel); o Blacklight exige o evento facebook.com/tr?ev=PageView. Presença do script × evento disparado.

uBlock Origin

Com o uBlock ligado: **89 bloqueios (16%)** e só **10 de 27 domínios conectados**. Bloqueados: doubleclick.net, googlesyndication.com, google-analytics.com, clarity.ms, facebook.net, ads-twitter.com, rubiconproject.com, scorecardresearch.com (comScore), permutive.app, imasdk.googleapis.com, mrf.io, dv.tech, entre outros. Permitidos: g1.globo.com, cloud.globo, subdomínios de glbimg.com, globovideos.com, gstatic.com. Parciais: globo.com, g.globo, s3.glbimg.com, googletagmanager.com.

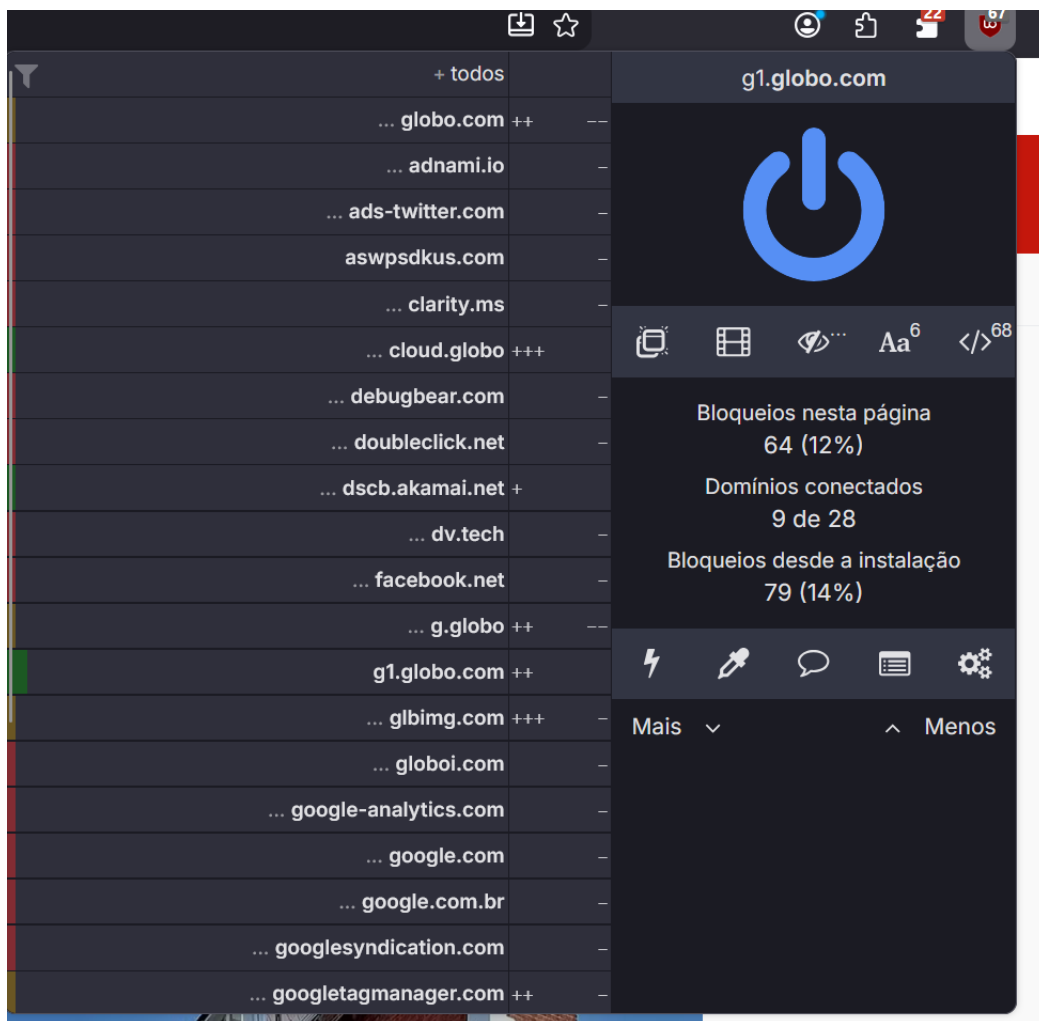


Figura 25 – uBlock Origin no g1 (início da lista) (evidencias/sites/site1-g1/9-ublock-a.png)

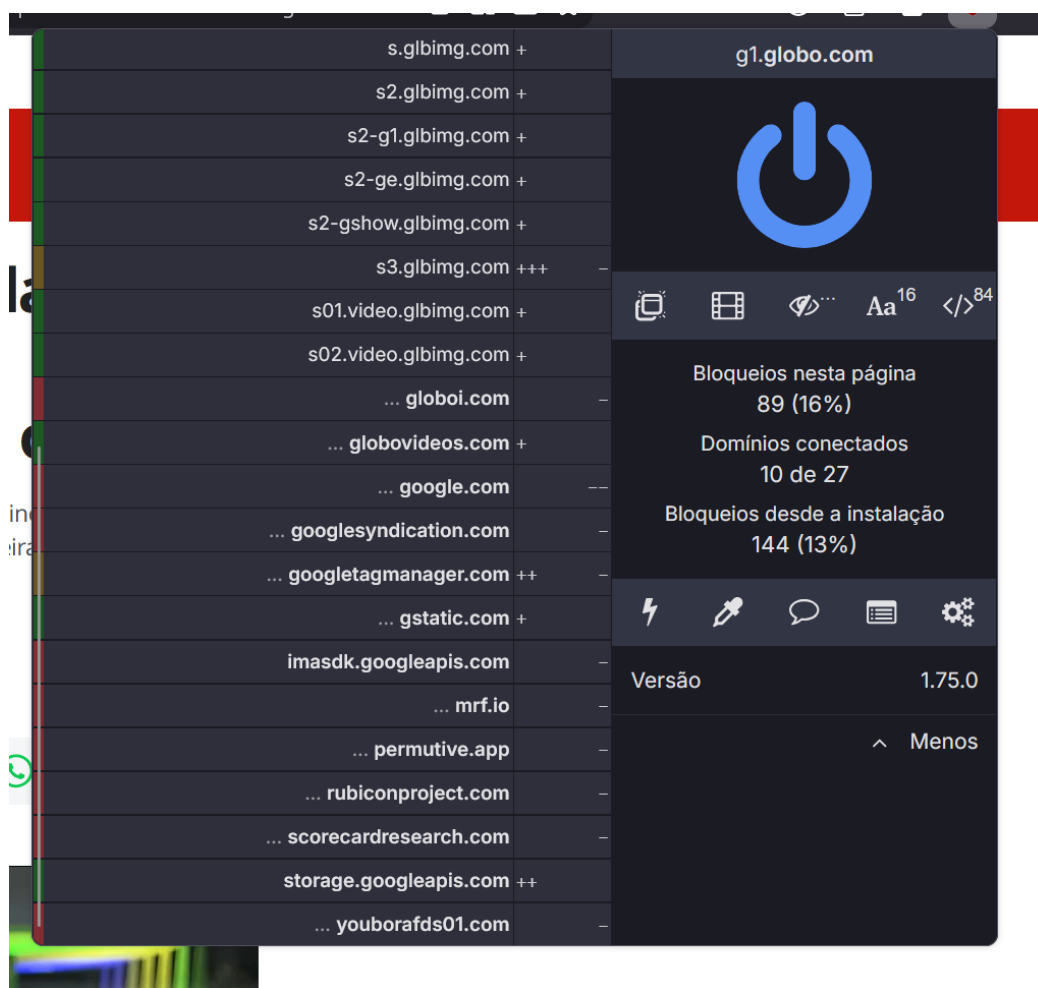


Figura 26 – uBlock Origin no g1 (fim da lista): 89 bloqueios, 10 de 27 domínios (evidencias/sites/site1-g1/9-ublock-c.png)

- **Efeito cascata:** Criteo, SmartAdServer, PubMatic, OpenX, ID5, Lotame e LiveIntent nem aparecem na lista do uBlock. Ao bloquear o Google Publisher Tag e o Prebid/Rubicon, o leilão não roda e os parceiros não são chamados. O mesmo efeito foi medido com a lista do plugin: bloqueando só doubleclick.net, o g1 caiu de ~72 para 28 domínios de 3ª parte e o score subiu de 19 para 30 (evidencias/extras e teste 7.3 no histórico).
- Tudo o que o uBlock bloqueou aparece no plugin como 3ª parte. O inverso (glbimg.com, g.globo, gstatic.com) é a divergência de critério: o uBlock filtra por **finalidade**, o plugin classifica por **domínio registrável**.
- O uBlock bloqueia **parcialmente** domínios da própria Globo por regras de **caminho**; o plugin bloqueia apenas por domínio.

4.4 mercadolive.com.br

HAR

Item	Valor
Arquivo	evidencias/sites/site2-mercadolive/site2-mercadolive.har (12,9 MB)
Requisições	216; status 200×199, 204×16, 301×1

Item	Valor
Domínios	11 eTLD+1, 10 de 3ª parte: mlstatic.com 164, mercadoclics.com 13, mercadolibre.com 12, meli.com 10, google.com 6, mercadolibre.com.br 5, hotjar.com 2, mercadolibre.com, mercadopago.com, mercadopago.com.br, gstatic.com
Cookies	41 Set-Cookie, 32 em respostas de 3ª parte: todos _d2id (grupo ML), exceto um NID do Google

Resultado do plugin

Score **57/100 (Ruim)**: domínios -10, cookies -18, session replay -5 (Hotjar), hijacking -10; sem sync, canvas ou storage de 3ª parte.

- Quase todo o tráfego de "3ª parte" é do **próprio grupo Mercado Livre** (CDN mlstatic.com, APIs mercadolibre.com/meli.com, rede de anúncios mercadoclics.com, mercadopago). Terceiros de fato: Google e Hotjar.
- **O mesmo cookie _d2id (ID de dispositivo) é gravado em 6 domínios do grupo**: print1.mercadoclics.com, melidata.mercadolibre.com, melidata.mercadolibre.com, melidata.mercadopago.com, melidata.mercadopago.com.br e o11y-proxy-otel-frontend.meli.com, todos com SameSite=None, expirando até 2029. É sincronização interna de identificador entre domínios.
- **Hotjar** carregado (static.hotjar.com/c/hotjar-720738.js), testando o storage (_hjLocalStorageTest, _hjSessionStorageTest); **Google Identity Services** (accounts.google.com/gsi/client, One Tap) gravando no sessionStorage.
- **Pollings** a cada ~5 s: o11y-proxy-otel-frontend.meli.com/v1/metrics (telemetria OpenTelemetry) e api.mercadolibre.com/melidata/tracks/component_prints (impressões de componentes, ou seja, o que o usuário viu).
- **5 funções nativas sobrescritas sem autor identificado** (fetch, XMLHttpRequest, open, send, toString). Hipótese: instrumentação OpenTelemetry, cujo uso é confirmado pelo endpoint o11y-proxy-otel.
- **LGPD**: o banner de cookies estava aberto e não foi aceito; mesmo assim já havia 9 cookies persistentes de 3ª parte, o Hotjar carregado e dois canais de rastreamento ativos.

Depuração - Tempo de execução x Gerenciador de extensões x Mercado Livre Brasil - Frete Grátis x

www.mercadolivre.com.br

Buscar produtos, marcas e muito mais...

Envie para São Paulo 05086090 Categorias > Ofertas Cupons Supermercado Moda Mercado Play Vender Contato

10.10 Até 12/10/2026. Ver mais em 10.10

ATE 70 APROVEITE

Frete grátis
Benefício por ser sua primeira compra.
[Mostrar produtos](#)

Entre na sua conta
Aproveite ofertas para comprar tudo que quiser.
[Entrar na sua conta](#)

Insira sua localização
Confira os custos e prazos de entrega.
[Informar localização](#)

Histórias Cruzadas
[Assistir grátis](#)

Meios de pagamento
Pague suas compras com rapidez e segurança.
[Mostrar meios](#)

Privacy Guard
www.mercadolivre.com.br (site: mercadolive.com.br)

SCORE DE PRIVACIDADE
57/100 Ruim

Começa em 100; cada critério desconta até o seu peso.

Critério	Pêda
Domínios de 3ª parte 10 domínio(s) x 1	-10 / 20
Cookies de 3ª parte 9 persistente(s) x 2 + 0 de sessão x 1	-18 / 20
Cookie sync, bounce e IDs na URL 0 sync + 0 bounce + 0 ID repetido x 5; 0 identificador(es) x 3; 0 parâmetro(s) de rastreamento x 2	-0 / 15
Canvas fingerprint nenhuma	-0 / 15
Session replay e pixels session replay: 1x1x1 x 5; pixels: nenhum x 3	-5 / 10
Hijacking/Hook 0 Websocket x 4; 2 polling x 2; 5 nativo(s) sem autor x 2; 0 com autor conhecido x 0.5	-10 / 10
Armazenamento de 3ª parte 0 chave(s) de 3ª parte x 2 + 4 de 1ª parte x 20	-0 / 10

DOMÍNIOS DE TERCEIRA PARTE
10 domínio(s) - 225 de 228 requisições são de 3ª parte

mlstatic.com
http2.mlstatic.com

Confira produtos com preços baixos.
[Mostrar produtos](#)

Usamos cookies para melhorar sua experiência no Mercado Livre. Consulte mais informações na nossa [Central de privacidade](#).

[Aceitar cookies](#) [Configurar cookies](#)

Inspeção de rede Console Depuração de rede Editor de estilo Desempenho Memória Armazenamento Acessibilidade Aplicação

Figura 27 – Mercado Livre: score 57/100 (Ruim), com o banner de cookies não aceito (evidencias/sites/site2-mercadolive/1-score.png)

74, con

BLOQUEADOS NESTA PÁGINA

0 requisição(ões) bloqueada(s) pela lista personalizada

COOKIES INJETADOS

	Sessão	Persistente	Total
1ª parte	1	5	6
3ª parte	0	9	9
Total	1	14	15

NID 3ª persistente
google.com/ (definido por play.google.com)
expira 30/03/2027 · Secure · HttpOnly · SameSite=none

_d2id 3ª persistente
mercadoclics.com/ (definido por print1.mercadoclics.com)
expira 28/09/2027 · Secure · SameSite=None

_d2id 3ª persistente
mercadolibre.com/ (definido por melidata.mercadolibre.com)
expira 27/09/2029 · Secure · SameSite=None

_d2id 3ª persistente
mercadolibre.com/ (definido por melidata.mercadolibre.com)

ARMAZENAMENTO HTML5

	1ª parte	3ª parte
localStorage	1	0
sessionStorage	3	0
indexedDB	0	0

https://www.mercadolibre.com.br

Confira produtos com
preços baixos.

Figura 28 – Mercado Livre: cookie _d2id em vários domínios do grupo (evidencias/sites/site2-mercadoLivre/3-cookies-storage.png)

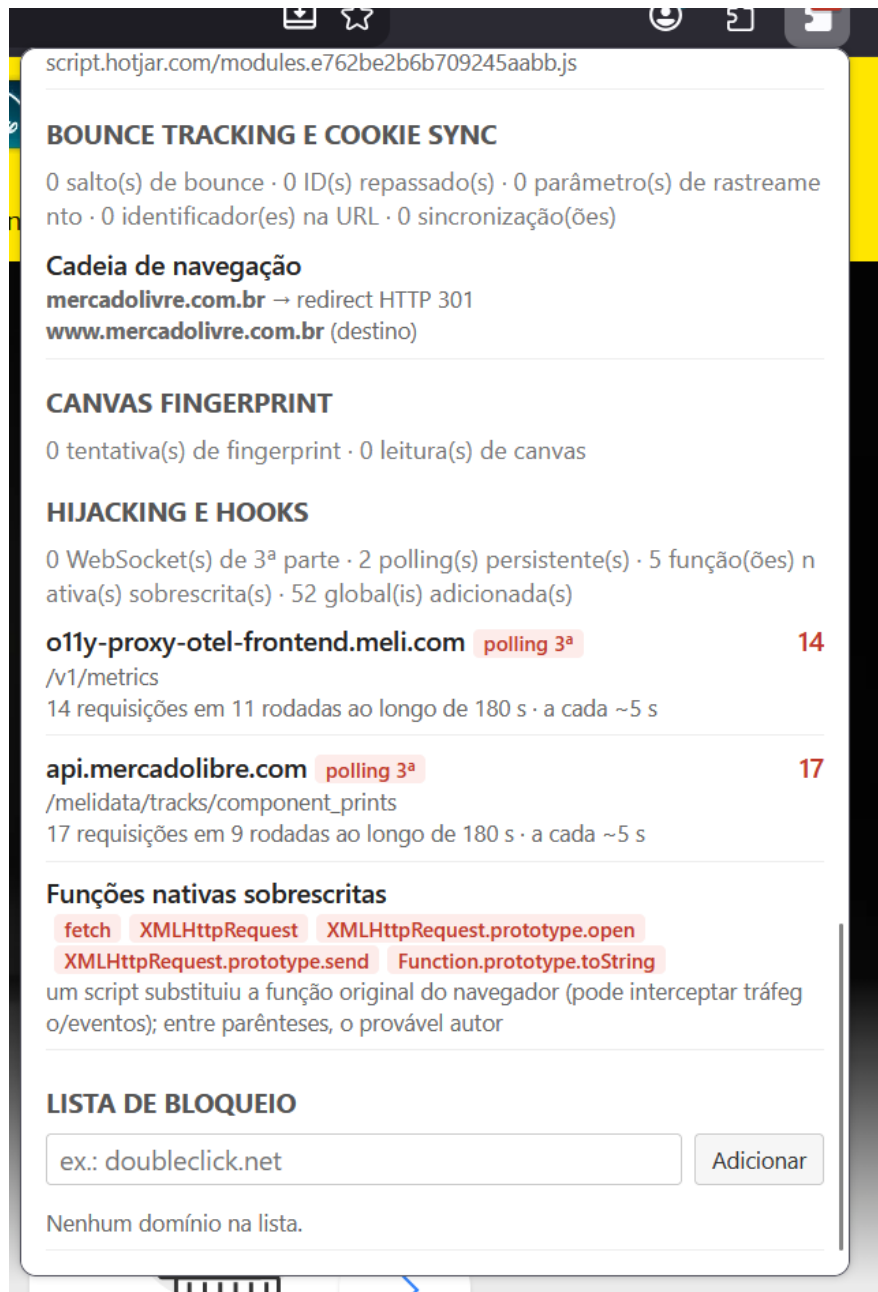


Figura 29 – Mercado Livre: pollings a cada ~5 s e funções nativas sobrescritas (evidencias/sites/site2-mercadoLivre/5-hijacking-polling-nativas.png)

Blacklight

0 ad trackers; 3 cookies de 3ª parte (mercadoclics.com, http2.mlstatic.com, o11y-proxy-otel-frontend.meli.com); fingerprint, session recording, keystrokes, pixels do Facebook/TikTok/X e GA remarketing não encontrados.

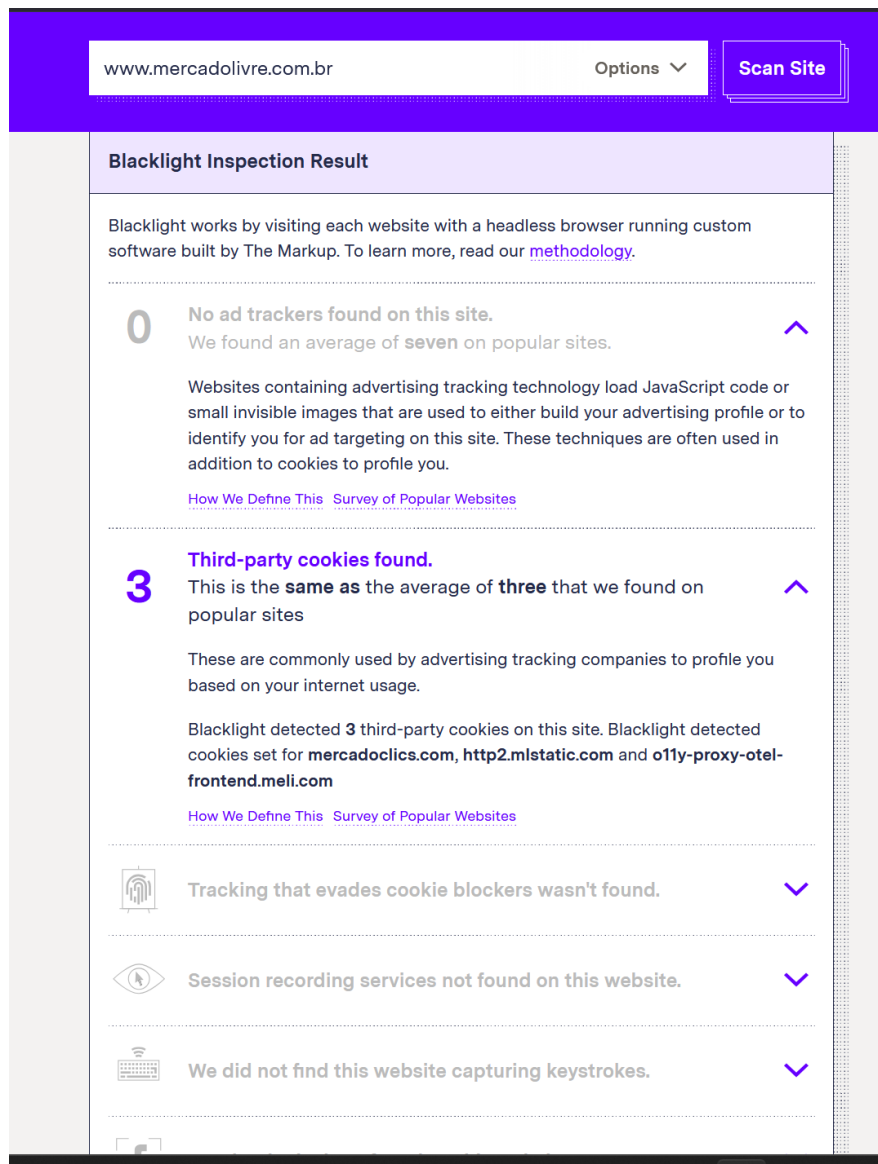


Figura 30 – Blacklight no Mercado Livre (evidencias/sites/site2-mercadoLivre/6-blacklight-a.png)

Reconciliação

- **0 ad trackers × 10 domínios:** os domínios do grupo ML não constam das listas de rastreadores de terceiros usadas pelo Blacklight; o plugin, por eTLD+1, conta todos.
- **3 × 9 cookies:** o HAR mostra que se trata do mesmo _d2id replicado em vários domínios. O plugin conta por nome + domínio (9), o Blacklight por domínio. Ambos corretos na sua unidade; o HAR revela o mecanismo.
- **Session recording** (Blacklight: não; plugin: Hotjar): o HAR tem apenas o script e o módulo do Hotjar, **sem** envio de gravação. O Hotjar carregou mas não gravou (amostragem ou consentimento). O plugin sinaliza o risco pela presença; o Blacklight exige a gravação ativa.
- Concordam: sem fingerprint, sem pixels de redes sociais, sem GA remarketing.

uBlock Origin

40 bloqueios (9%), 8 de 10 domínios conectados. Bloqueados: hotjar.com e mercadoclics.com; parciais: mercadolive.com.br e google.com; permitidos: mlstatic.com,

mercadolivre.com, meli.com. O uBlock revelou que placements.mercadolivre.com e o1ly-proxy-otel-frontend.meli.com são CNAMEs de *.cloudfront.net.

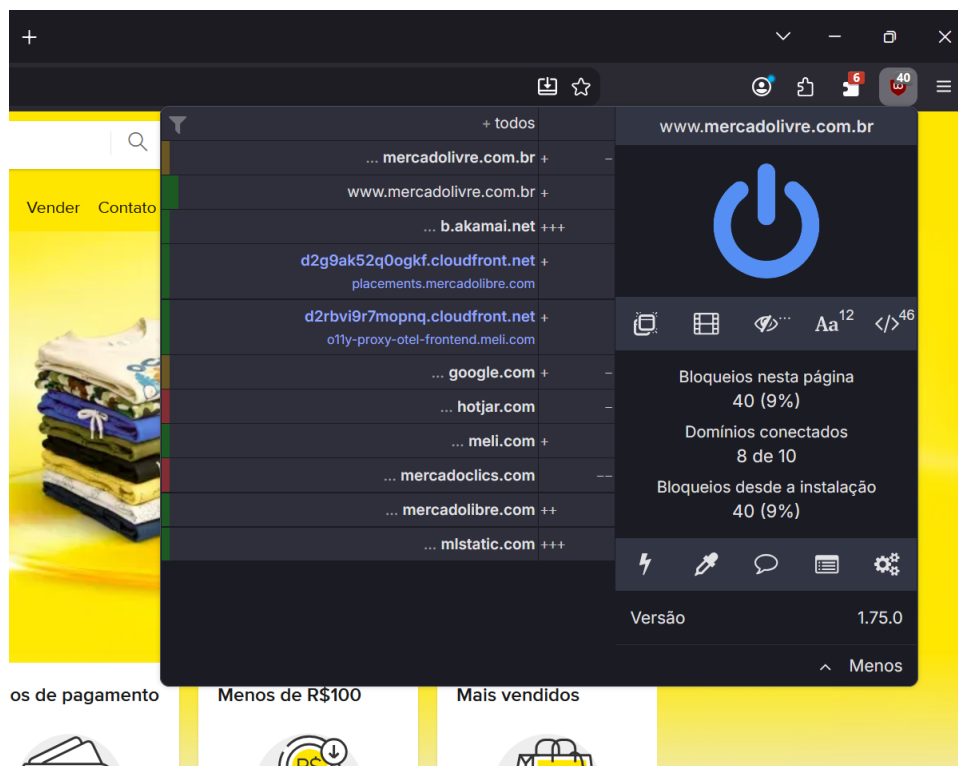


Figura 31 – uBlock Origin no Mercado Livre (evidencias/sites/site2-mercadoLivre/7-ublock.png)

- **uBlock bloqueia mercadoclics.com, o Blacklight não o lista:** as duas ferramentas de referência divergem entre si. O plugin fica do lado do uBlock: registra as requisições e o cookie _d2id desse domínio.
- **CNAME uncloaking:** o uBlock resolve DNS para descobrir o destino real de subdomínios "de 1ª parte". O plugin só compara nomes; um rastreador servido por CNAME de 1ª parte seria classificado como 1ª parte (limitação).

4.5 pt.wikipedia.org (site de controle)

HAR

Item	Valor
Arquivo	evidencias/sites/site3-wikipedia/site3-wikipedia.har (3,4 MB)
Requisições	36; hosts pt.wikipedia.org 24, thumb.wikimedia.org 5, meta.wikimedia.org 2, auth.wikimedia.org 1, upload.wikimedia.org 1
Domínios	Apenas wikipedia.org e wikimedia.org, ambos da Wikimedia Foundation; nenhum anunciante, rede social ou analytics externo
Cookies	31 Set-Cookie, todos Wikimedia: WMF-Last-Access, WMF-Last-Access-Global, GeoIP (sessão), NetworkProbeLimit, WMF-Uniq

Resultado do plugin

Score **80/100 (Moderada)**: domínios **-1** (wikimedia.org) e **cookies -19** (9 persistentes + 1 de sessão, todos de wikimedia.org); zero em todos os demais critérios. O storage de 1ª parte

tem 8 chaves de métricas próprias (CentralNotice, contagem de sessão, cache de módulos), e as 39 globais são todas do MediaWiki.

Privacy Guard
pt.wikipedia.org (site: wikipedia.org)

SCORE DE PRIVACIDADE

80/100 **Moderada**

Começa em 100; cada critério desconta até o seu peso.

Critério	Perda
Domínios de 3ª parte 1 domínio(s) × 1	-1 / 20
Cookies de 3ª parte 9 persistente(s) × 2 + 1 de sessão × 1	-19 / 20
Cookie sync, bounce e IDs na URL 0 sync + 0 bounce + 0 ID repassado (× 5), 0 identificador(es) × 3, 0 parâmetro(s) de rastreamento × 2	-0 / 15
Canvas fingerprint nenhuma	-0 / 15
Session replay e pixels session replay: nenhum (× 5); pixels: nenhum (× 3)	-0 / 10
Hijacking/hook 0 WebSocket × 4, 0 polling × 2, 0 nativa(s) sem autor × 2, 0 com autor conhecido × 0,5	-0 / 10
Armazenamento de 3ª parte 0 chave(s) de 3ª parte × 2 + 8 de 1ª parte ÷ 20	-0 / 10

DOMÍNIOS DE TERCEIRA PARTE
1 domínio(s) · 11 de 33 requisições são de 3ª parte

wikimedia.org **Bloquear** **11**
thumb.wikimedia.org, meta.wikimedia.org, auth.wikimedia.org, upload.wikimedia.org

☐ Automático

Figura 32 – Wikipedia: score 80/100 (evidencias/sites/site3-wikipedia/1-score.png)

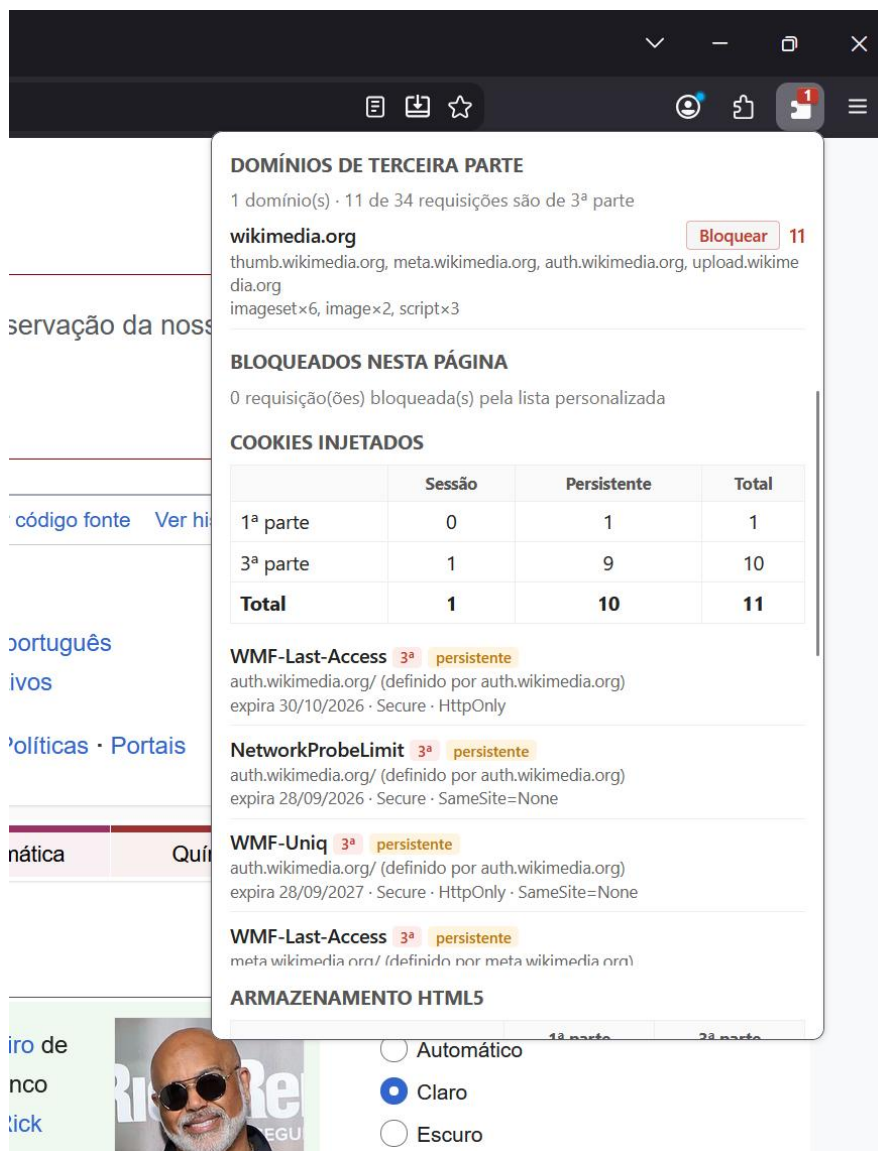


Figura 33 – Wikipedia: 1 domínio de 3ª parte (wikimedia.org) e seus cookies (evidencias/sites/site3-wikipedia/2-terceira-parte-cookies.png)

Blacklight e uBlock Origin

Blacklight: **0 ad trackers** e **4 cookies de 3ª parte** ("Wikimedia Foundation, Inc."); nada nos demais testes. uBlock: **0 bloqueios**, 2 de 2 domínios conectados.

pt.wikipedia.org/wiki/Wikip%C3%A9dia:P%C3%A1gir
Options
Scan Site

Blacklight Inspection Result

Blacklight works by visiting each website with a headless browser running custom software built by The Markup. To learn more, read our [methodology](#).

0
No ad trackers found on this site.
We found an average of **seven** on popular sites.

4
Third-party cookies found.
This is **more than** the average of **three** that we found on popular sites

These are commonly used by advertising tracking companies to profile you based on your internet usage.

Blacklight detected **4** third-party cookies on this site. Blacklight detected a cookie set for **Wikimedia Foundation, Inc.**

[How We Define This](#)
[Survey of Popular Websites](#)


Tracking that evades cookie blockers wasn't found.


Session recording services not found on this website.


We did not find this website capturing keystrokes.


Facebook Pixel not found on this website.


TikTok Pixel not found on this website.


X Pixel not found on this website.

Figura 34 – Blacklight na Wikipedia: 4 cookies de 3ª parte da Wikimedia (evidencias/sites/site3-wikipedia/5-blacklight-a.png)

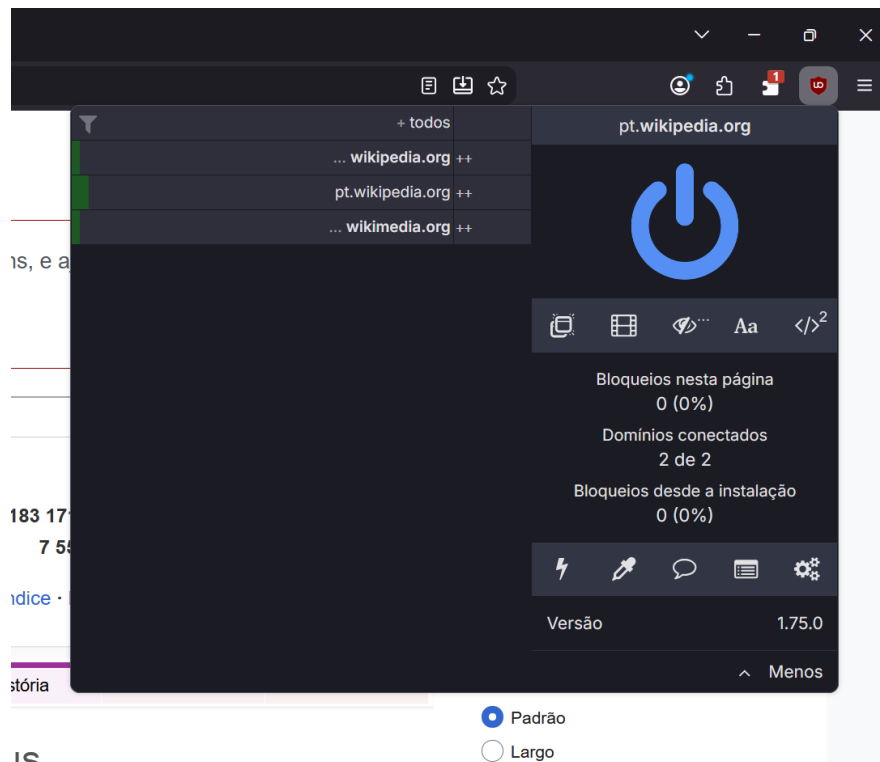


Figura 35 – uBlock Origin na Wikipedia: 0 bloqueios (evidencias/sites/site3-wikipedia/6-ublock.png)

Reconciliação

- As três ferramentas concordam: nenhum rastreador de anúncio. O Blacklight **também** classifica os cookies de wikimedia.org como de 3ª parte: é o mesmo critério por domínio do plugin.
- **4 × 10 cookies:** diferença de unidade. São 4 nomes de cookie persistente; o plugin conta cada nome por subdomínio que o grava (auth., meta., thumb., upload.wikimedia.org).
- A divergência relevante é de **peso**, discutida na Seção 5: 10 cookies de infraestrutura levam a Wikipedia a perder 19 pontos, o mesmo patamar de sites com dezenas de cookies de anunciantes.

5. Entregável 4: pontuação de privacidade

5.1 Metodologia

A página começa com **100 pontos** e perde pontos em **7 critérios**. Cada critério tem um **peso**, que é a perda máxima possível nele; os pesos somam 100. Dentro do peso, a perda cresce com a quantidade observada. O score é recalculado cada vez que o popup é aberto.

Critério	Peso	Regra de perda	Justificativa
1. Domínios de 3ª parte	20	1 por domínio (eTLD+1)	Cada terceiro recebe IP, User-Agent e Referer do usuário em toda requisição: é a base de qualquer rastreamento entre sites.
2. Cookies de 3ª parte	20	2 por persistente, 1 por sessão	Principal mecanismo de identificação entre sites; o persistente sobrevive ao fechamento do navegador.
3. Cookie sync, bounce e IDs na URL	15	5 por sync, bounce ou ID repassado; 3 por identificador na URL; 2 por parâmetro de rastreamento	Ligam identidades entre domínios e contornam o isolamento de cookies do navegador.
4. Canvas fingerprint	15	15 se o script é de 3ª parte; 10 se de 1ª	Identifica o dispositivo sem cookie e sem que o usuário consiga apagar.
5. Session replay e pixels	10	5 por session replay (Clarity, Hotjar, FullStory); 3 por pixel (Meta, TikTok, LinkedIn, UET), por fornecedor	Gravação de sessão captura cliques e digitação; pixels enviam a navegação a plataformas de anúncio. Correspondem a testes do Blacklight.
6. Hijacking/hook	10	4 por WebSocket de 3ª; 2 por polling; 2 por nativa sobrescrita sem autor; 0,5 com autor conhecido	Canal persistente e interceptação de APIs são o que um script injetado precisa para receber comandos e ler o tráfego.
7. Armazenamento de 3ª parte	10	2 por chave de 3ª parte; 1 a cada 20 chaves de 1ª	Storage de 3ª parte guarda IDs fora do alcance da limpeza de cookies; o de 1ª parte costuma ser estado do próprio site.

Regra especial: a assinatura do **BeEF** limita o score a **20**, independentemente do resto, porque um framework de exploração ativo significa navegador comprometido, e não só rastreado. **Faixas:** 85–100 **Boa**; 65–84 **Moderada**; 40–64 **Ruim**; 0–39 **Crítica**. Requisições bloqueadas pela lista não contam, porque não aconteceram.

5.2 Calibração

Antes do uso nos sites, a metodologia foi simulada com os números medidos nos testes, e três falhas foram corrigidas:

- A simulação do BeEF no `example.com` dava **88 (Boa)**, uma nota absurda para um navegador comprometido. Isso levou à regra do teto de 20.
- Um site fictício com 12 rastreadores e 4 cookies persistentes de 3ª parte dava **80 (Boa)**. As faixas foram apertadas (85/65/40) e ele passou a Moderada.
- O storage de 1ª parte do g1 (94 chaves ÷ 10 = -9) pesava demais para dados do próprio site. O divisor passou a ser 20.

Após os testes no Firefox, a contagem de pixels passou a ser por fornecedor (fbq e _fbq são o mesmo Meta Pixel).

5.3 Aplicação aos 3 sites

Critério (peso)	g1.globo.com	mercadolivre.com.br	pt.wikipedia.org
1. Domínios de 3ª (20)	-20 (87)	-10 (10)	-1 (1)
2. Cookies de 3ª (20)	-20 (65 pers. + 2 sessão)	-18 (9 pers.)	-19 (9 pers. + 1 sessão)
3. Sync/bounce/IDs (15)	-15 (82 syncs)	0	0
4. Canvas (15)	0	0	0
5. Replay/pixels (10)	-8 (Clarity + Meta Pixel)	-5 (Hotjar)	0
6. Hijacking/hook (10)	-10 (23 pollings, 7 nativas)	-10 (2 pollings, 5 nativas)	0
7. Armazenamento 3ª (10)	-10 (2 de 3ª + 129 de 1ª)	0 (4 de 1ª)	0 (8 de 1ª)
Score	17 – Crítica	57 – Ruim	80 – Moderada

5.4 Comparação crítica com o Blacklight

O Blacklight não atribui nota: ele reporta testes como presentes ou ausentes. A comparação foi feita critério a critério, mapeando os critérios do score aos testes equivalentes.

Critério do score	Teste do Blacklight	g1	Mercado Livre	Wikipedia
1. Domínios de 3ª	Ad trackers	87 × 27 (diverge na contagem)	10 × 0 (diverge)	1 × 0
2. Cookies de 3ª	Third-party cookies	67 × 14 (ambos altos)	9 × 3	10 × 4 (concordam na classificação)
3. Sync/bounce	(sem equivalente)	82 syncs	0	0
4. Canvas	Tracking que evade bloqueio de cookies	0 × não (concordam)	0 × não (concordam)	0 × não (concordam)
5. Replay/pixels	Session recording; Facebook/TikTok/X pixel	Clarity + Meta × só "tells X" (diverge)	Hotjar × nada (diverge)	nada × nada (concordam)
6. Hijacking	(sem equivalente; keystrokes é o mais próximo)	pollings e nativas	pollings e nativas	0
7. Storage 3ª	(sem equivalente)	2 chaves	0	0

Onde concordam

- **Ordenação dos sites:** o Blacklight aponta muitos problemas no g1 (27 ad trackers, 14 cookies, X, GA remarketing) e poucos no Mercado Livre e na Wikipedia; o score coloca g1 (17) muito abaixo de Mercado Livre (57) e Wikipedia (80).
- **Canvas fingerprint:** ausente nos 3 sites para as duas ferramentas.
- **Classificação de cookies da Wikimedia** como 3ª parte em pt.wikipedia.org: o mesmo critério por domínio.
- **Pixels do Facebook/TikTok e GA remarketing** no Mercado Livre e na Wikipedia: ausentes para ambos.

Onde divergem e por quê

6. **Unidade de terceiro:** o Blacklight conta rastreadores de anúncio de listas conhecidas; o plugin conta todo domínio registrável diferente. Por isso o Mercado Livre tem 0 ad

trackers no Blacklight e 10 domínios no plugin, quase todos do próprio grupo ML, inclusive a rede de anúncios mercadoclics.com, que o uBlock bloqueia.

7. **Presença × comportamento:** para session recording e Facebook Pixel, o Blacklight exige o comportamento durante a varredura (gravação enviada, evento disparado); o plugin pontua a presença do script. No g1, o HAR prova a coleta do Clarity (i.clarity.ms/collect a cada ~16 s); no Mercado Livre, o HAR mostra o Hotjar carregado sem gravar. O plugin é mais conservador: pontua o risco potencial.
8. **Contexto da varredura:** o Blacklight visitou como celular na Califórnia; as medições do plugin foram feitas num desktop no Brasil. Leilões de anúncio, parceiros de sincronização e scripts condicionados a país mudam (ex.: RTB House presente só no Blacklight; dezenas de cookies de parceiros só no Brasil).
9. **Contagem de cookies:** o plugin conta por nome + domínio + path (e por subdomínio); o Blacklight agrega. Isso explica 4×10 na Wikipedia e 3×9 no Mercado Livre sem diferença de classificação.
10. **O que o Blacklight não mede:** cookie sync, bounce tracking, polling, funções nativas sobrescritas e storage de 3ª parte. Foram esses critérios que diferenciaram o g1 (82 syncs, hsid enviado ao Google, 23 pollings) e mostraram o _d2id replicado em 6 domínios do Mercado Livre.

Limitações do score e melhorias

- **Entidade × domínio:** a Wikipedia perdeu 19 pontos por cookies de infraestrutura de wikimedia.org, mesma organização; o g1 e o Mercado Livre também são penalizados pela própria CDN. Melhoria: mapa de entidades (como o *Tracker Radar* do DuckDuckGo ou o entities.json do Disconnect) e contagem de cookies por nome, não por subdomínio. Não foi aplicada nesta entrega para manter os três sites medidos com a mesma metodologia.
- **Finalidade:** o score não distingue um ID sincronizado entre domínios (_d2id) de um cookie de contagem de acessos (WMF-Last-Access). Ponderar pelo valor identificador do cookie tornaria o critério 2 mais justo.
- **Deteção por nome:** pixels e session replay são reconhecidos por globais conhecidas; ferramentas fora da lista não pontuam no critério 5.
- **CNAME cloaking:** o plugin não resolve DNS; um rastreador disfarçado de 1ª parte não seria contado.
- Os pesos são uma escolha de projeto justificada, e não uma medida absoluta de risco.

6. Conclusão

A extensão cumpriu todos os requisitos do roteiro e foi validada em 13 cenários de 8 páginas das DuckDuckGo Privacy Test Pages e em 3 sites reais, com HAR, Blacklight e uBlock Origin como referência. Nas páginas de teste, o plugin detectou os 5 rastreadores do Tracker Reporting, os 4 caminhos de canvas fingerprint, o bounce com ID repassado, os parâmetros de rastreamento (4/4 igual ao DDG) e bloqueou os 23 mecanismos do Tracker Blocking com a lista personalizada.

Os testes também serviram para corrigir a própria extensão: nove defeitos foram encontrados em uso real e corrigidos, entre eles a evasão por iframe usada pelo BrowserLeaks e a interferência do canal postMessage que quebrava o teste de Storage Partitioning, identificada comparando a mesma página com e sem a extensão.

Nos sites reais, o score ordenou os sites de forma coerente com o Blacklight (g1 17, Mercado Livre 57, Wikipedia 80) e foi além dele: mostrou o identificador `hsid` da Globo sendo enviado ao Google, os 23 canais de polling do g1 e o mesmo ID de dispositivo replicado em 6 domínios do Mercado Livre antes de qualquer consentimento. As divergências com o Blacklight e o uBlock foram todas explicadas pelo tráfego no HAR: critério de terceiro (domínio × entidade × lista), presença × comportamento, contexto geográfico da varredura e unidade de contagem.

Anexo A: evidências no repositório

Pasta	Conteúdo
evidencias/ddg/	29 prints das 8 páginas do DDG: tracker-reporting-1 a 5, storage-blocking-1 e 2, fingerprinting-1 e 2, bounce-tracking-1 a 3, query-parameters-1 a 4, tracker-blocking-1 a 4, storage-partitioning (aba de teste, erro, sem e com extensão), js-leaks
evidencias/sites/site1-g1/	site1-g1.har; prints 1 a 6 do popup; 7 e 8 do Blacklight; 9a a 9c do uBlock Origin
evidencias/sites/site2-mercadolivre/	site2-mercadolivre.har; prints 1 a 5 do popup; 6a e 6b do Blacklight; 7 do uBlock Origin
evidencias/sites/site3-wikipedia/	site3-wikipedia.har; prints 1 a 4 do popup; 5a e 5b do Blacklight; 6 do uBlock Origin
evidencias/extras/	BrowserLeaks antes e depois da correção, simulação de BeEF/WebSocket, instalação via about:debugging
README.md	Instalação, arquitetura, critérios de cada detecção e metodologia completa do score